

SEC102 :

MENACES INFORMATIQUES ET CODES
MALVEILLANTS
ANALYSE ET LUTTE

<https://lecnam.net>

Date: 16/06/2025

Présenté par : Anthony DESSIATNIKOFF



Calendrier prévisionnel de la formation

Cours	Date	Titre	Enseignant
01	20/03/2025	Introduction à la gestion de l'incident de sécurité en entreprise	Fabrice CRASNIER
02	14/04/2025	Posture de la DSI face à un incident de sécurité	Fabrice CRASNIER
03	22/05/2025	Analyse mémoire	Maxime ROSINSKI
04	16/06/2025	Le métier de pentester et ses contraintes	Anthony DESSIATNIKOFF
05	18/06/2025	La levée de doute	Fabrice CRASNIER

Calendrier prévisionnel de la formation

Cours	Date	Titre	Enseignant
06	19/06/2025	Les méthodes d'intrusion sur les systèmes et Présentation des audits de sécurité	Anthony DESSIATNIKOFF
07	07/07/2025	Investigation sur le système	Anthony DESSIATNIKOFF
08	08/07/2025	Investigation sur le réseau	Maxime ROSINSKI
09	09/07/2025	L'investigation forensique, analyse post mortem	Fabrice CRASNIER
10	10/07/2025	L'après incident de sécurité, obligations et poursuites judiciaires	Fabrice CRASNIER

Calendrier prévisionnel de la formation

Cours	Date	Titre	Enseignant
11	11/07/2025	Analyse de malwares	Anthony DESSIATNIKOFF
12	18/08/2025	Développer un plan de remédiation après un incident de sécurité.	Maxime ROSINSKI
13	19/08/2025	Investigation, analyse et remédiation : mise en application dans l'embarqué 1/2	Maxime ROSINSKI
14	20/08/2025	Investigation, analyse et remédiation : mise en application dans l'embarqué 2/2 + Révision	Maxime ROSINSKI
15	21/08/2025	Examen	Maxime ROSINSKI

Table des matières

Le métier de pentester (ou testeur d'intrusion) consiste à simuler des cyberattaques sur des systèmes informatiques, des applications ou des réseaux afin d'identifier des vulnérabilités exploitables.

L'objectif est d'aider les entreprises à renforcer leur posture de sécurité et à prévenir les cyberattaques réelles.



Introduction aux tests d'intrusion

Le métier de pentester :

- **Procédé d'un test d'intrusion et le cadre légal**
- **Le rapport**
- **Méthodologie**
- **Les limites et contraintes**

Les CVE



Introduction aux tests d'intrusion

Principe : Simuler des attaques réelles pour cibler une infrastructure, un réseau, un système, un matériel ou une application pour y détecter des faiblesses.

Objectif : détecter des vulnérabilités et lister les recommandations associées.

Livrables pour le client :

- Rapport avec liste des vulnérabilités et recommandations associées
- Présentation en présentiel ou à distance

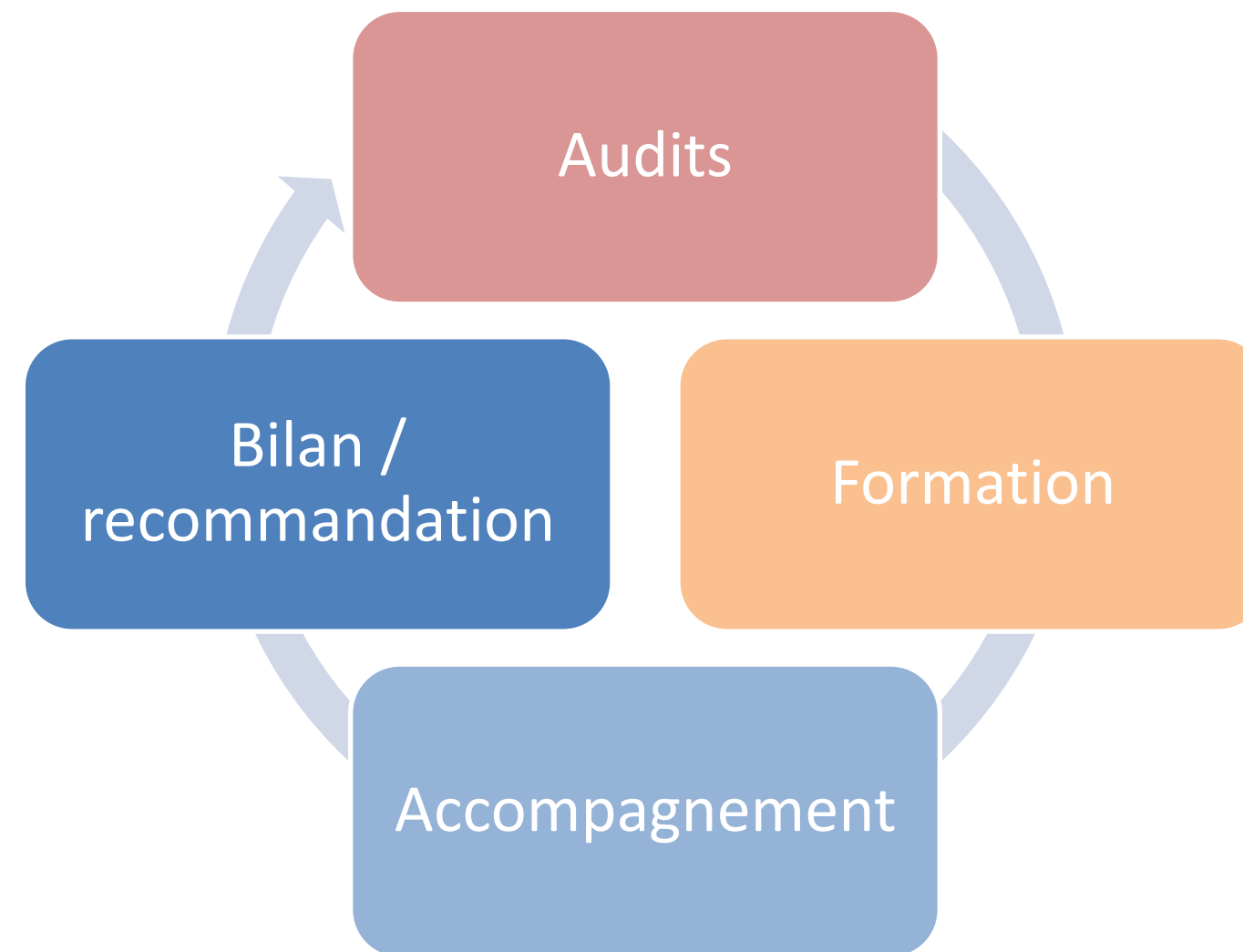
Pourquoi un auditeur ne doit pas faire les corrections ?

- Objectivité
- Confiance
- Vérification indépendante
- Respect des normes

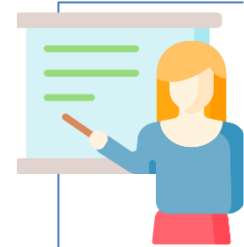


Introduction aux tests d'intrusion

**Processus
d'amélioration continue
en cybersécurité**



Pourquoi tant de vulnérabilités ?



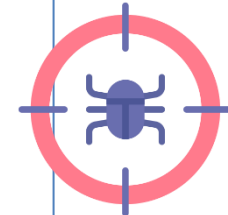
Sensibilisation
faible à la cyber



Budget parfois
insuffisant



Dev sécurisé



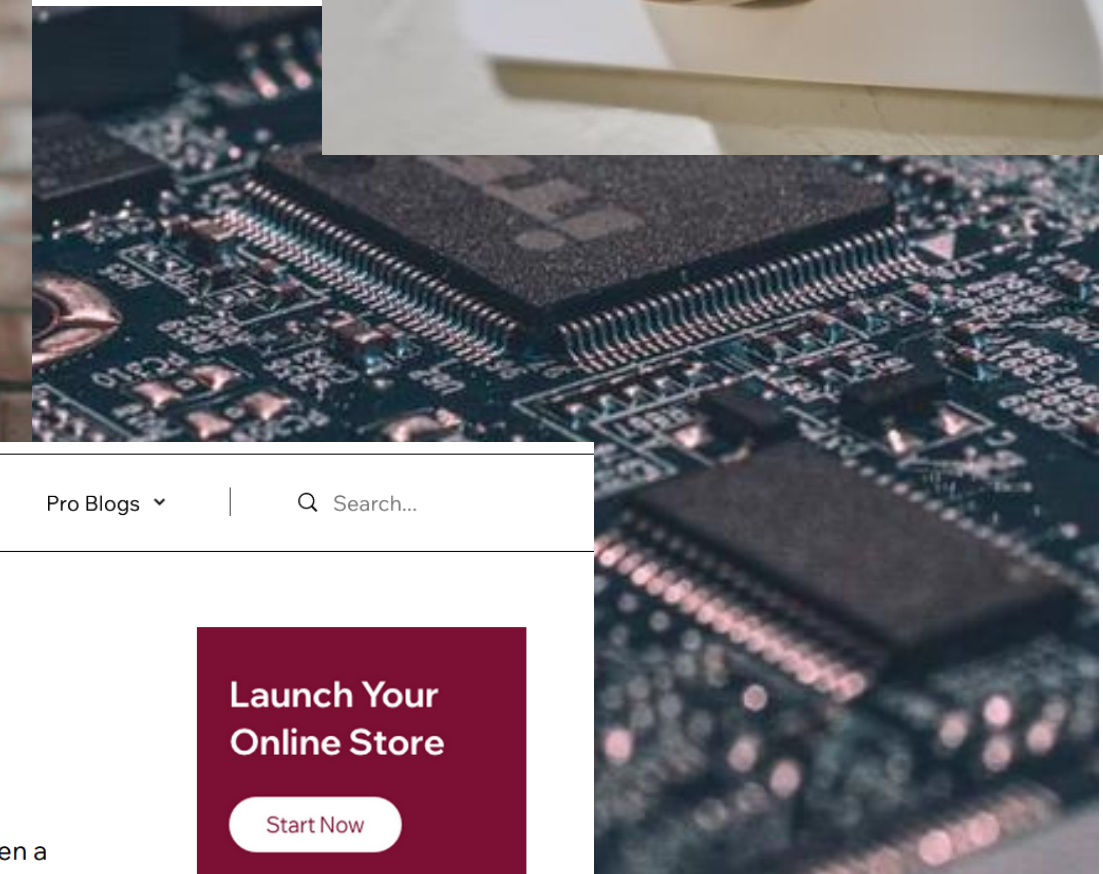
Vulnérabilités
résiduelles



Certifications
mal comprises

Introduction aux tests d'intrusion

- Tout ce qui a une connexion avec l'extérieur (IP, Bluetooth, Wi-Fi, ZigBee, firmware, etc.)



04. The Spice Suite - Bringing Your Whole Self to Your eCommerce Website

With the boom in eCommerce shopping, there has also been a boom in eCommerce competition. To set yourself apart, it's

Launch Your
Online Store

Start Now

Exemple : Routeur Netgear Nighthawk RAX30



Mise à jour automatique du firmware

Fournit les derniers correctifs de sécurité au routeur

Accès au réseau invités

Accès séparé et sécurisé pour les clients

APPLICATION NIGHTHAWK®

Configurez facilement votre routeur et tirez le meilleur parti de Votre WiFi

↑ Application Android et Apple

Technologie Wifi : WiFi 6 (802.11ax) WiFi Dual Band (AX5200) 2,4 GHz et 5 GHz

- Vitesse Wifi : AX2400 (574 + 1 800 Mbit/s)
- Bande Wifi : Dual band 5 GHz + 2,4 GHz
- Ports Gigabit Ethernet : 5 ports Ethernet Gigabit 10/100/1 000 Mbit/s (1 port WAN et 4 ports LAN)
- Processeur : Puissant processeur Triple core de 1,5 GHz
- Ports USB : Un (1) port USB 3.0



Le métier de pentester

- Des missions de pentest pour une entreprise pendant quelques jours (3 à 5 jours en général mais peut aller jusqu'à des semaines)
- Un cadre strict à respecter (obligation légale)
- Rédaction du rapport et présentation des résultats à l'entreprise auditée



Contraintes des tests d'intrusion

- Nombre de jours d'audit limité (fonction du prix et type de tests)
- Impossibilité de garantir l'absence de vulnérabilité :
 - Garantie de **moyen** et non de résultat !
- Impossibilité de réaliser des tests exhaustifs
- Reco. de l'ANSSI : réaliser un audit de code source en plus d'un test d'intrusion

Procédé d'un test d'intrusion

3 étapes :

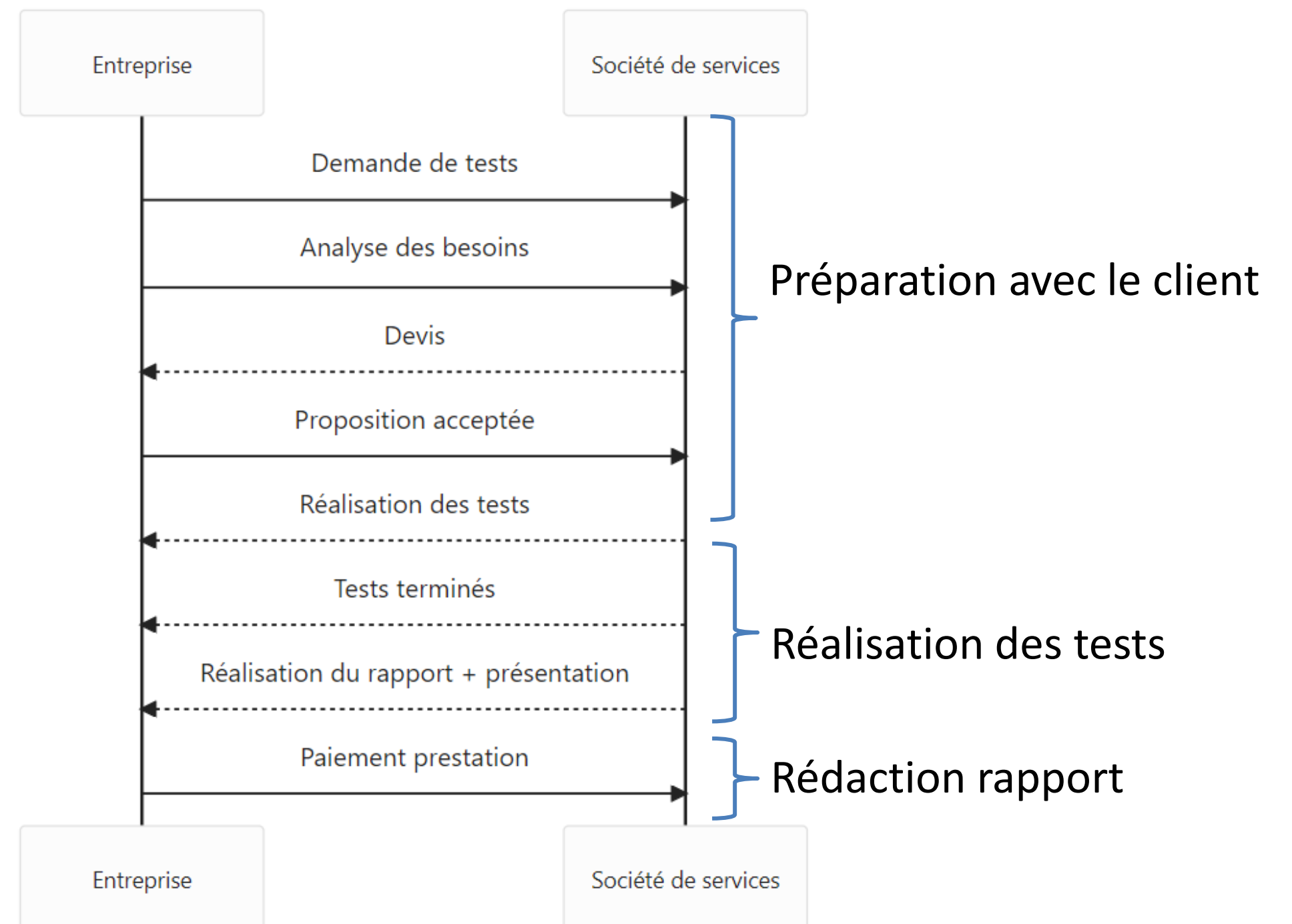
1. Préparation



2. Réalisation



3. Rédaction





Quelques normes ISO liées aux tests d'intrusion

- **ISO 27001 : Management de la sécurité de l'information**
 - La norme ISO/CEI 27001 décrit les **exigences** pour la mise en place d'un Système de Management de la Sécurité de l'Information (SMSI).
 - Fortes recommandations de réaliser des tests d'intrusion tous les ans pour les systèmes sensibles
 - Certifications de personnes : ISO 27001 Lead Auditor (LA), ISO 27001 Lead Implementer (LI)

- **ISO 27034 : Sécurité des applications**
 - Fondements sur la sécurité des applications

- **ISO 19011 : Audit des systèmes de management**
 - Déontologie, impartialité, confidentialité, indépendance, approche fondée sur la preuve, approche par les risques



Définitions (ISO/IEC 27000)

- **Vulnérabilité** : la faille dans un actif ou dans une mesure de sécurité qui peut être exploitée par une ou plusieurs menaces.
- Types de vulnérabilités :
 - Matériel : Maintenance insuffisante, mauvaise installation des supports de stockage
 - Logiciel : Tests de logiciel absents ou insuffisants
 - Réseau : Canaux de communications non protégés
 - Personnel : Formation insuffisante à la sécurité
 - Site : Réseau électrique instable
 - Organisme : Absence de responsabilités en sécurité



Définitions (ISO/IEC 27000)

- **Menace** : Cause potentielle d'un incident indésirable, qui peut nuire à un système ou à un organisme
- Types de menaces :
 - Dommages physiques
 - Catastrophes naturelles
 - Perte de services essentiels
 - Perturbation due à des rayonnements
 - Compromission d'informations
 - Défaillances techniques
 - Actions non autorisées
 - Compromission des fonctions

Vulnérabilité et menace

Vulnérabilité	Menace
Entrepôt non protégé et sans surveillance	Vol
Procédures compliquées de traitement des données	Erreur d'entrée des données par le personnel
Pas de séparations des tâches	Fraude, utilisation non autorisée d'un système
Données non chiffrées	Vol de données
Pas de revue des droits d'accès	Accès non autorisé par des personnes ayant quitté l'organisme
Pas de procédure de sauvegarde	Perte d'information



Définitions (ISO/IEC 27000)

- La **sécurité de l'information** est la protection de la **confidentialité**, de l'**intégrité** et la **disponibilité** de l'information.
- **Confidentialité** : propriété selon laquelle l'information n'est pas diffusée ni divulguée à des personnes, des entités ou des processus non autorisés.
- **Intégrité** : propriété d'exactitude et de complétude
- **Disponibilité** : propriété d'être accessible et utilisable à la demande par une entité autorisée.



Définitions (ISO/IEC 27000)

- Risque de sécurité de l'information :

Vraisemblance
(probabilité
d'occurrence)



Conséquence
(impact)



Risque



21

ANSSI : Agence Nationale de Sécurité des Systèmes d'Information

- Rattaché au SGDSN
- Créé en 2009
- Environ 650 agents
- Budget : 100 millions €
- Directeur : Vincent Strubel (depuis janvier 2023)

- De nombreux guides créés pour les entreprises, les administrations et les particuliers
- Des visas de sécurité délivrés (qualifications, certifications)



cyber.gouv.fr

www.cert.ssi.gouv.fr

 [@ANSSI_FR](https://twitter.com/ANSSI_FR)



22

ANSSI : la qualification PASSI

- Prestataire d'Audit de la Sécurité des Systèmes d'Informations (PASSI)
- Plusieurs types d'audits (appelés **portées**) :
 - Audit de configuration
 - Audit d'architecture
 - Audit organisationnel et physique
 - Audit de code source
 - Test d'intrusion
 - (Audit de systèmes industriels)

<https://cyber.gouv.fr/actualites/appel-public-commentaires-sur-la-mise-jour-du-referentiel-passi>

ANSSI : Agence Nationale de Sécurité des Systèmes d'Information

Facilité d'exploitation Impact	Difficile	Elevée	Modérée	Facile
Mineur	Mineur	Mineur	Important	Majeur
Important	Mineur/Important ⁹	Important	Important	Majeur
Majeur	Important	Majeur	Majeur	Critique
Critique	Important	Majeur	Critique	Critique



Facilité d'exploitation (PASSI)

- La facilité d'exploitation correspond au niveau d'expertise et aux moyens nécessaires à la réalisation de l'attaque. Elle est appréciée selon l'échelle suivante :
 - *Facile* : exploitation **triviale**, sans outil particulier ;
 - *Modérée* : exploitation nécessitant des **techniques** simples et des outils disponibles **publiquement** ;
 - *Elevée* : exploitation de vulnérabilités publiques nécessitant des **compétences** en sécurité des systèmes d'information et le **développement** d'outils simples ;
 - *Difficile* : exploitation de vulnérabilités **non publiées** nécessitant une **expertise** en sécurité des systèmes d'information et le développement d'outils spécifiques et ciblés.



Niveau d'impact (PASSI)

- L'impact correspond aux conséquences que l'exploitation de la vulnérabilité peut entraîner sur le système d'information de l'audité. Il est apprécié selon l'échelle suivante :
 - *Mineur* : **pas** de conséquence directe sur la sécurité du système d'information audité ;
 - *Important* : conséquences **isolées** sur des points précis du système d'information audité ;
 - *Majeur* : conséquences **restreintes** sur une partie du système d'information audité ;
 - *Critique* : conséquences **généralisées** sur l'ensemble du système d'information audité.

ANSSI : la qualification PASSI

 Avantages	 Inconvénients
Être reconnu par l'ANSSI pour sa qualité de prestation	Examen difficile pour l'auditeur
Vendre des audits PASSI (vendus plus chers)	Coût élevé pour l'entreprise
Visibilité sur le site de l'ANSSI	Mise en place difficile pour l'entreprise



27

Compétences de l'auditeur en test d'intrusion

Techniques :

- Réseaux et protocoles
- Equipements et logiciels de sécurité
- Systèmes d'exploitation
- Couche applicative
- Connaitre les attaques et contournement

Qualités :

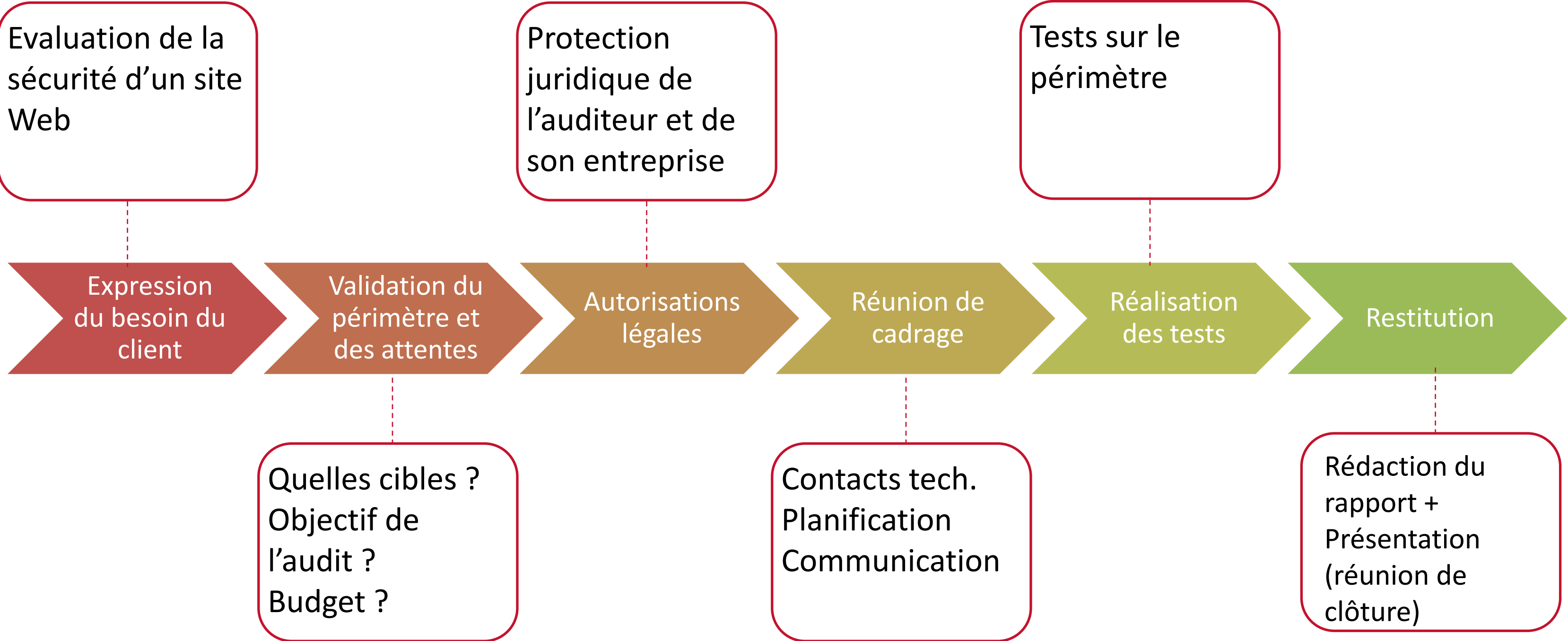
- savoir **synthétiser** et **restituer** l'information utile pour du personnel technique et non technique ;
- savoir rédiger des rapports et des documentations adaptées à différents niveaux d'interlocuteurs (services techniques, organe de direction, etc.) ;
- savoir travailler en équipe (partage de connaissances, collaboration technique et entraide).

<https://cyber.gouv.fr/actualites/appel-public-commentaires-sur-la-mise-jour-du-referentiel-passi>

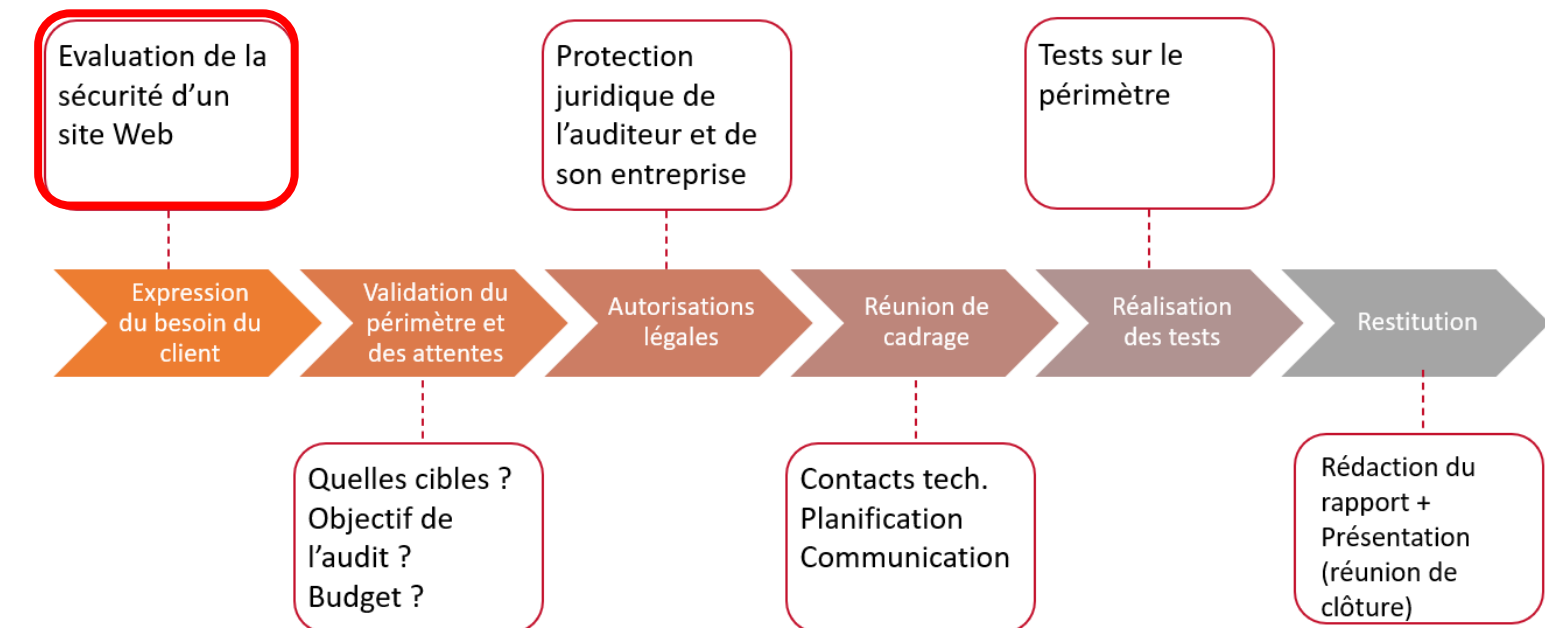


28

Déroulé d'un audit



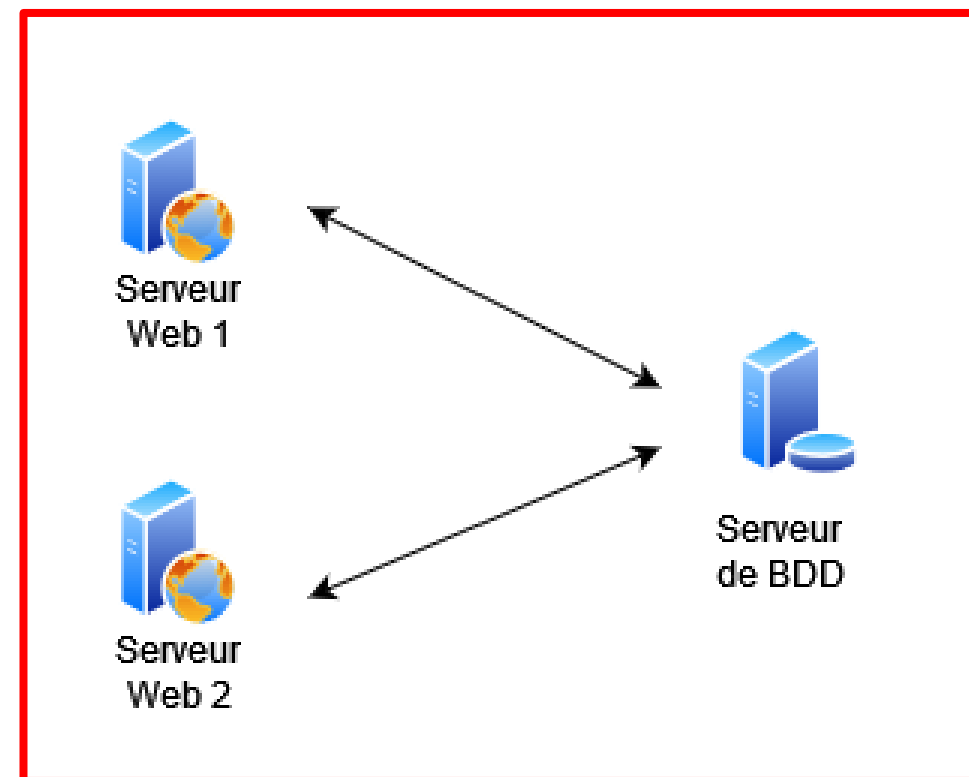
29 Préparation de l'audit



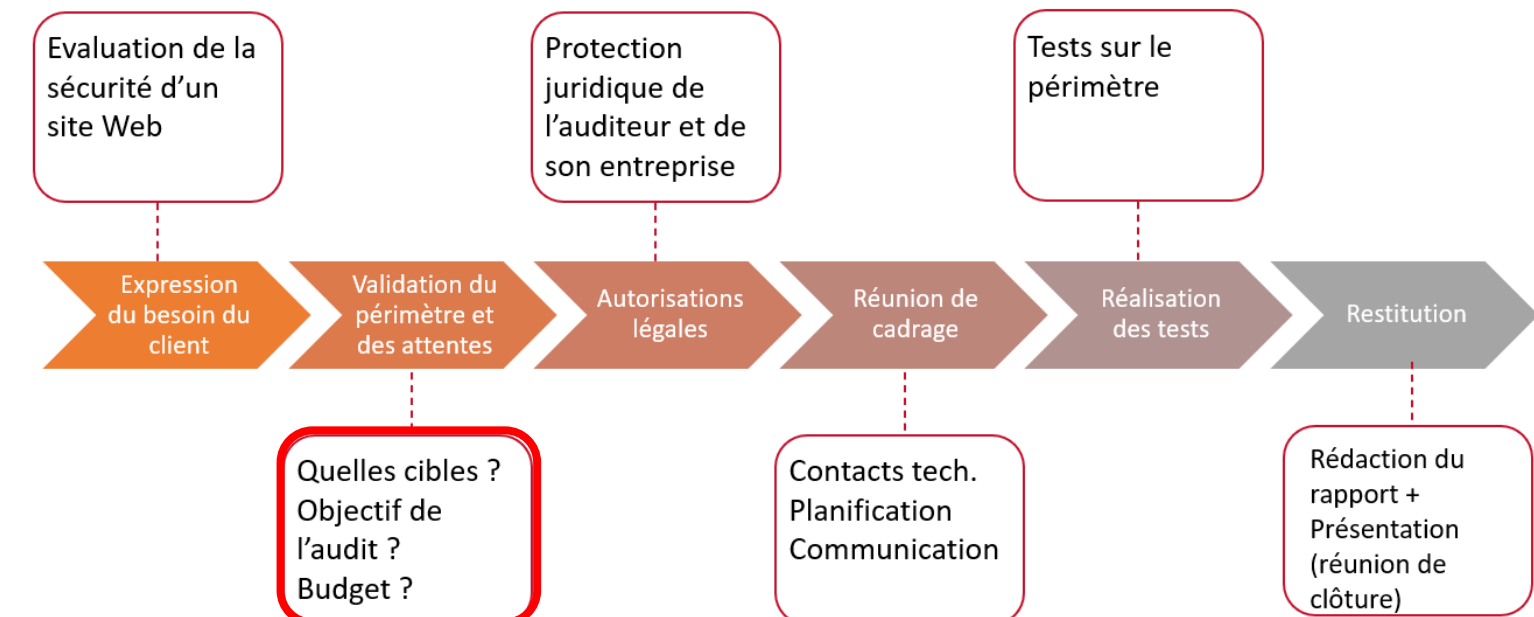
- Réunion avec le client : définir le périmètre, besoins du client, scénario d'attaques, types de tests, les livrables, communication pendant l'audit, les interlocuteurs, définir les dates, obligation de moyens, etc.
- Signature d'une **convention d'audit** (ou de service) pour les tests d'intrusion sur son infrastructure.
- Le document d'autorisation des tests peut être intégré à la convention d'audit ou à part. Il contient les IP ou domaines du périmètre.

Validation du périmètre

- Questions à se poser :
 - Tester les autorisations entre utilisateurs ?
 - Tester uniquement les défigurations de site ?
 - Tester uniquement les WAF ?
 - Tester uniquement les vulnérabilités de type RCE ?

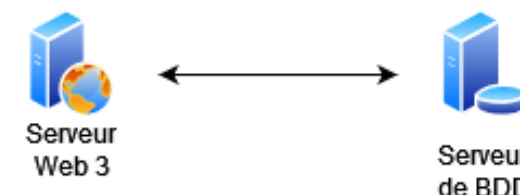
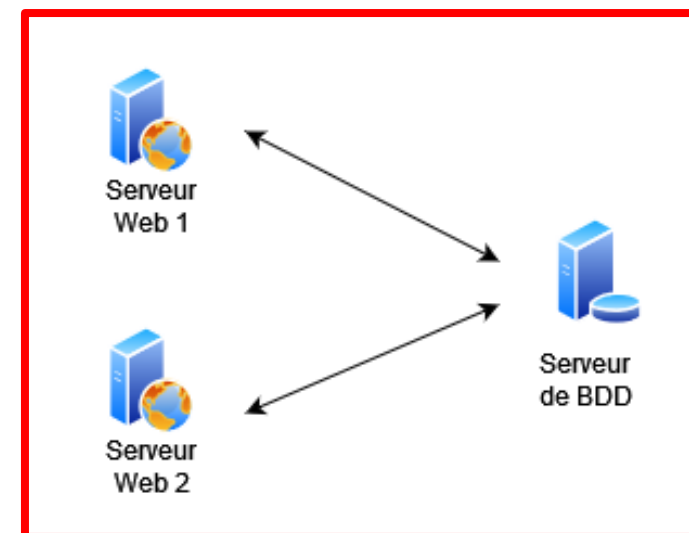
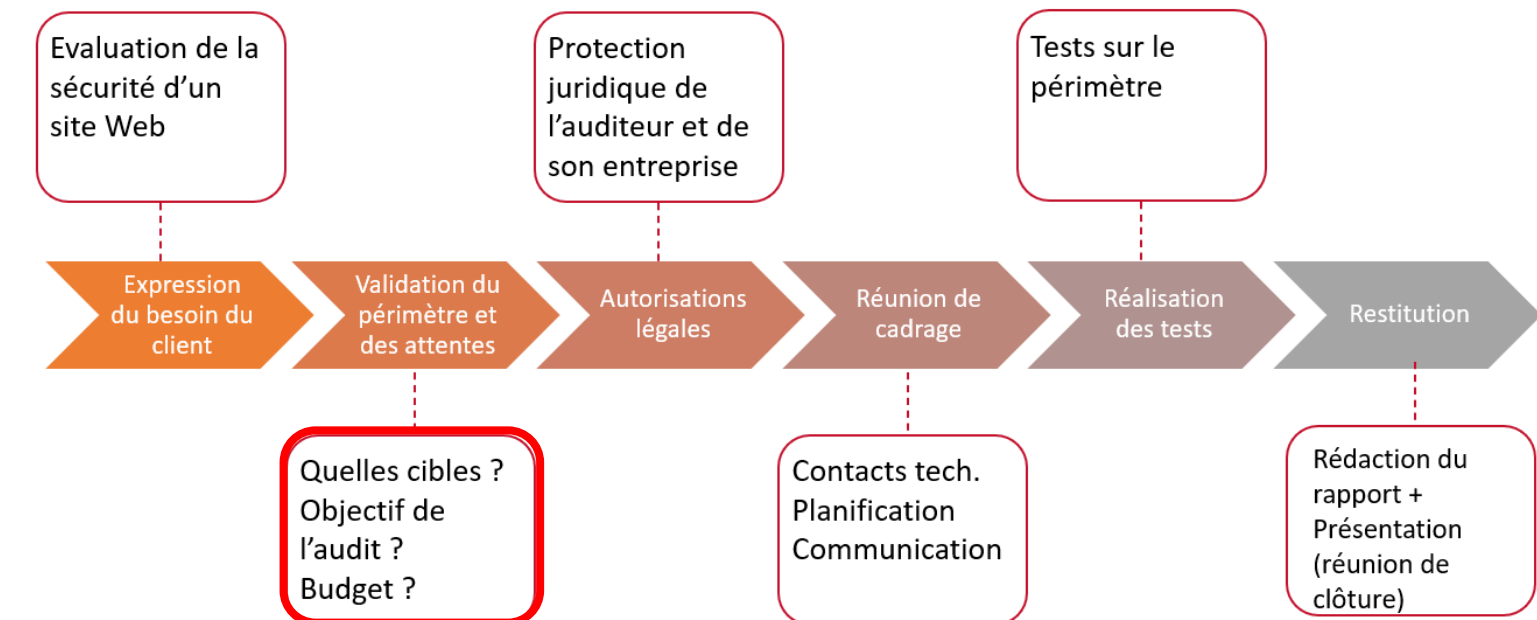


Ex : Tester uniquement les 2 sites de ventes et la BDD mais pas le site qui contient les ressources statiques.

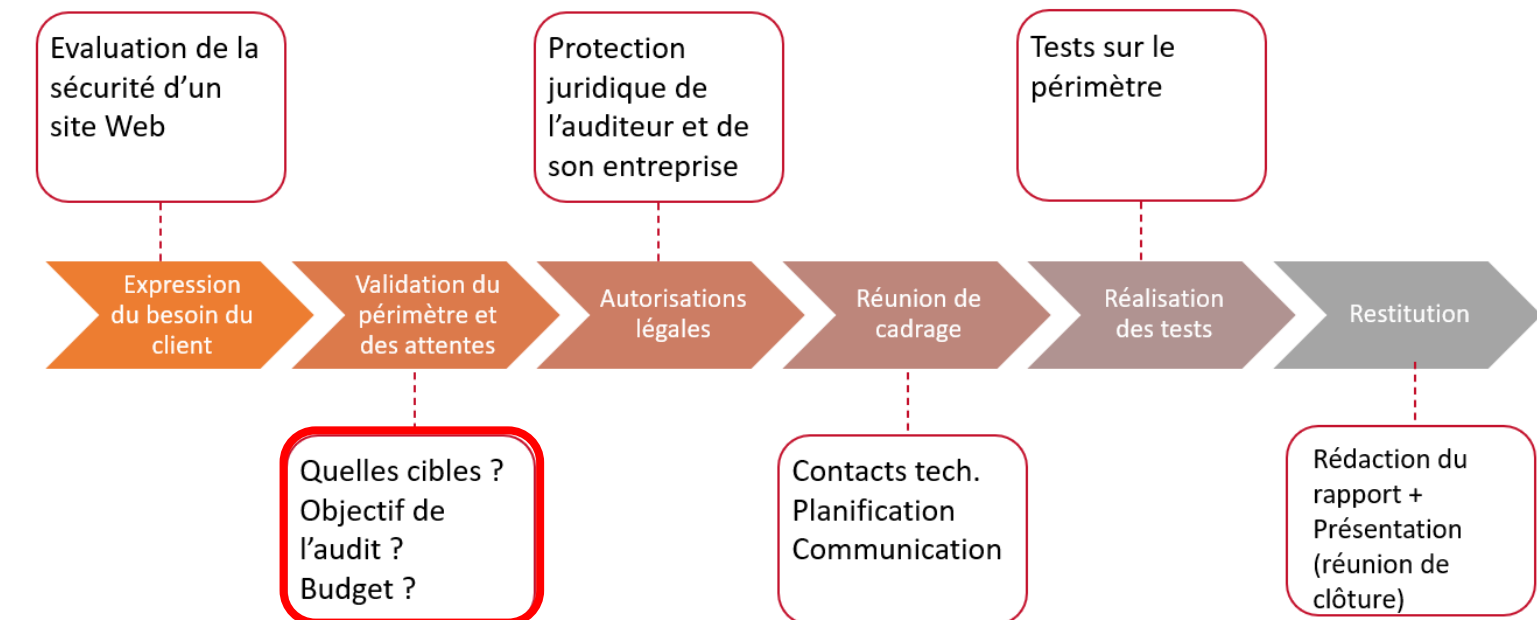


31 Validation du périmètre

- Quels sont les scénarios à tester ?
 - Fuite de données
 - Autorisations entre utilisateurs
 - OSINT
 - Exécution de code
 - Elévation de privilèges
 - Etc.

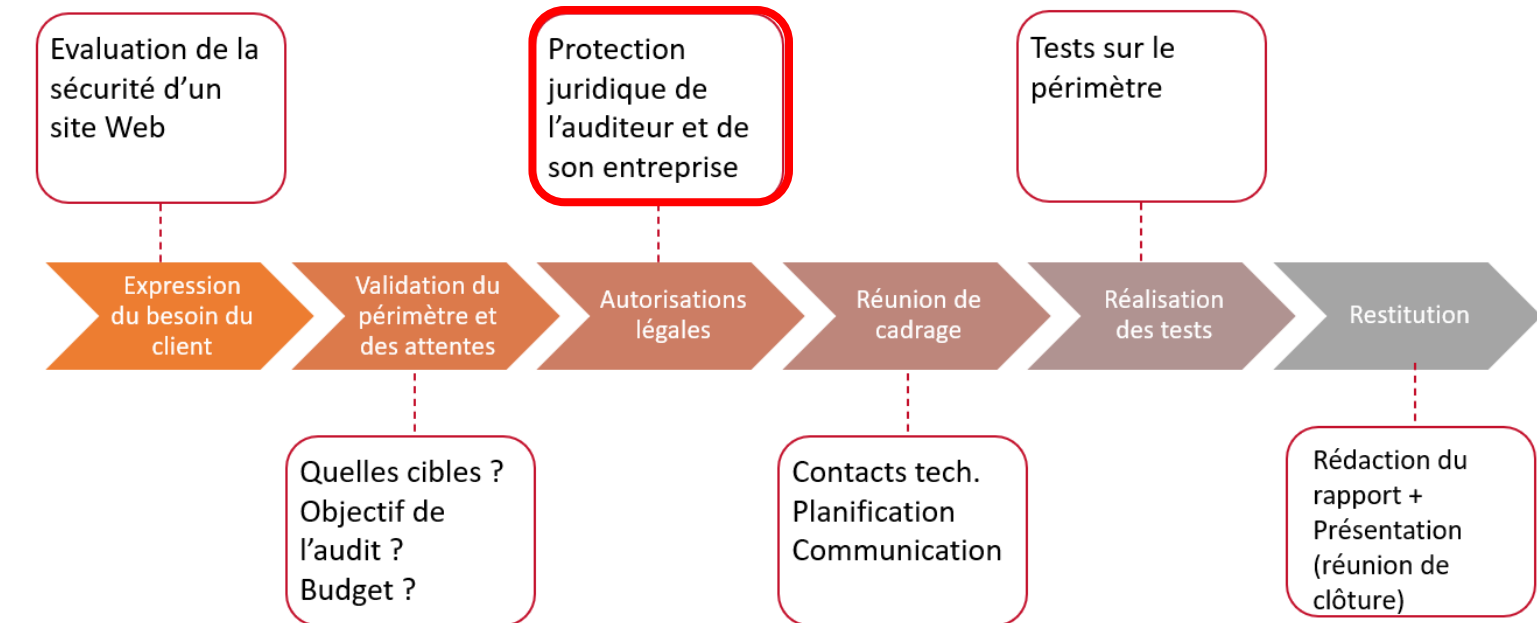


32 Définir le budget



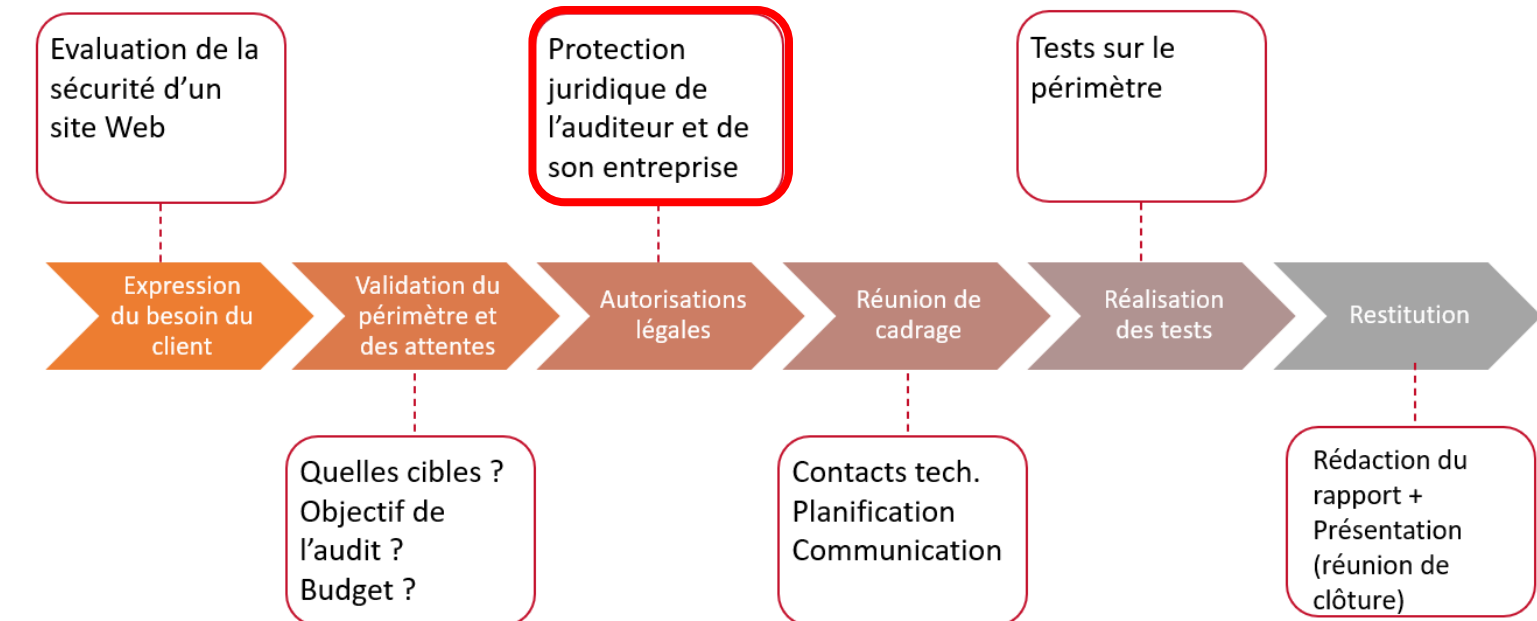
- Types de paiement de la prestation :
 - Au forfait (durée fixe) : possible pour un faible périmètre.
 - En régie (au temps passé) :
 - Ex. : Avec un budget de 9000 €, 720 € / jour pendant 12,5 jours (9000/720)
- A partir de cette durée de 12,5 jours, que peut-on faire ?

33 Autorisation des tests



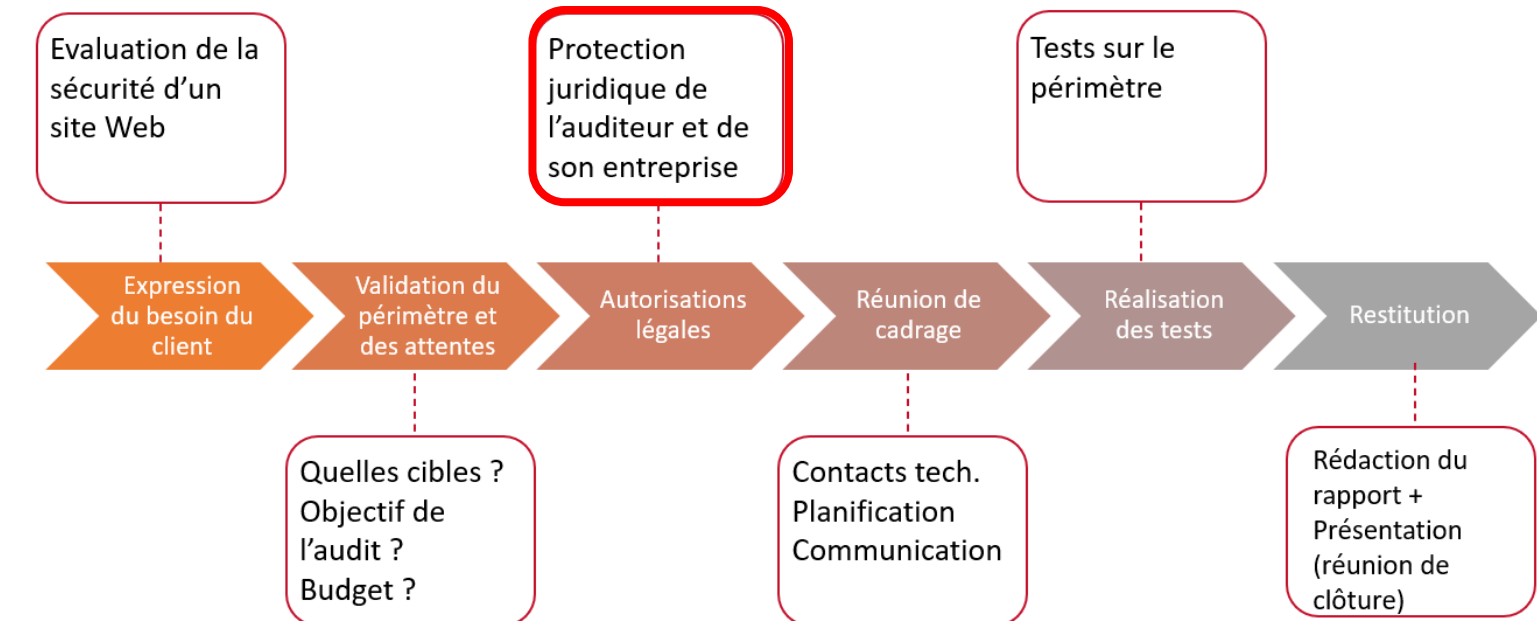
- Le client et les auditeurs signent le document d'autorisation des tests.
- Le client s'engage à ne pas poursuivre les auditeurs pour infraction dans le système.

34 Cadre légal 1/2



- Si l'auditeur (et sa société) n'est pas autorisé expressément par le commanditaire, il encourt les infractions suivantes (modifié le 26/01/2023) :
 - Code pénal, art. 323-1 :
 - Le fait d'accéder ou de se maintenir, frauduleusement, dans tout ou partie d'un système de traitement automatisé de données est puni de **deux ans d'emprisonnement** et de **60 000 € 100 000 €** d'amende.
 - Lorsqu'il en est résulté soit la suppression ou la modification de données contenues dans le système, soit une altération du fonctionnement de ce système, la peine est de **trois** cinq ans d'emprisonnement et de **100 000 150 000 €** d'amende.
 - Lorsque les infractions prévues aux deux premiers alinéas ont été commises à l'encontre d'un système de traitement automatisé de données à caractère personnel mis en œuvre **par l'Etat**, la peine est portée à **cinq** sept ans d'emprisonnement et à **150 000 300 000 €** d'amende.
 - Code pénal, art. 323-2 :
 - Le fait d'entraver ou de fausser le fonctionnement d'un système de traitement automatisé de données est puni de **cinq ans d'emprisonnement** et de **150 000 €** d'amende.
 - Lorsque cette infraction a été commise à l'encontre d'un système de traitement automatisé de données à caractère personnel mis en œuvre par l'Etat, la peine est portée à sept ans d'emprisonnement et à 300 000 € d'amende.
 - Code pénal, art. 323-3 :
 - Le fait d'introduire frauduleusement des données dans un système de traitement automatisé, d'extraire, de détenir, de reproduire, de transmettre, de supprimer ou de modifier frauduleusement les données qu'il contient est puni de cinq ans d'emprisonnement et de 150 000 € d'amende.
 - Lorsque cette infraction a été commise à l'encontre d'un système de traitement automatisé de données à caractère personnel mis en œuvre par l'Etat, la peine est portée à sept ans d'emprisonnement et à 300 000 € d'amende.

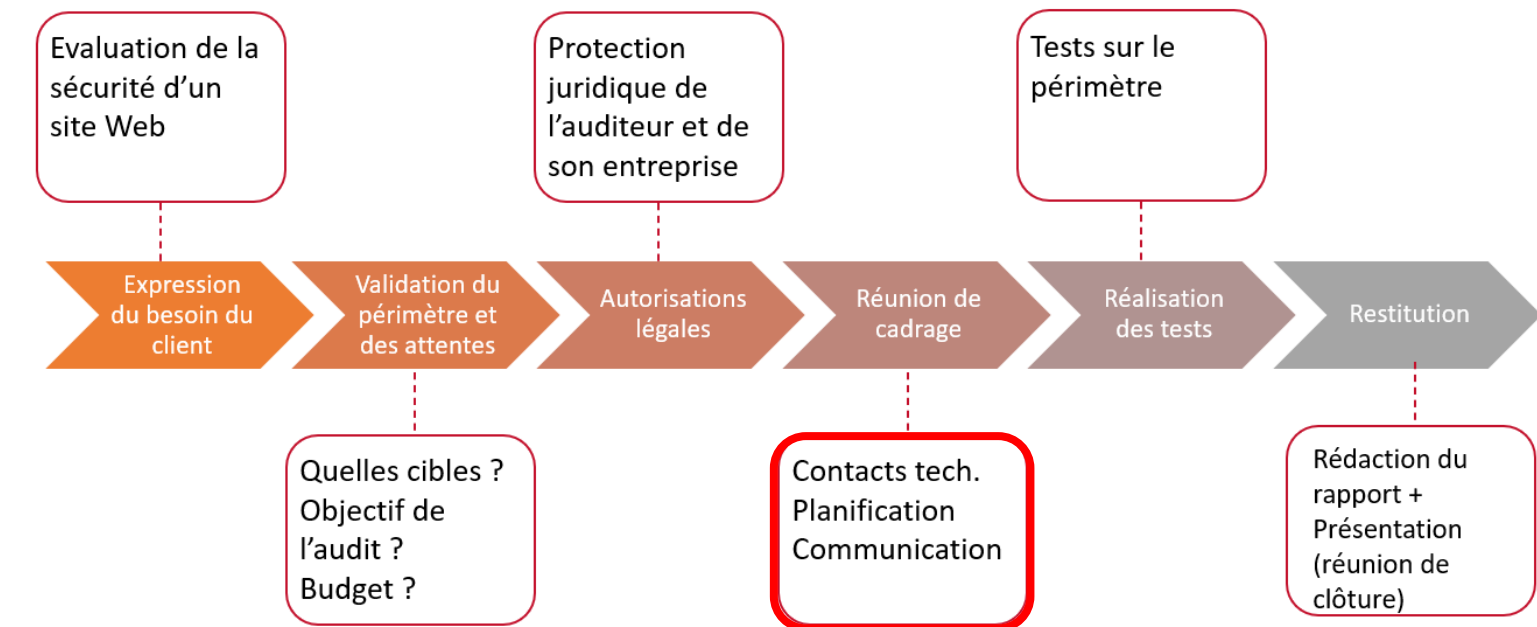
35 Cadre légal 2/2



- Si l'auditeur (et sa société) n'est pas autorisé expressément par le commanditaire, il encourt les infractions suivantes :
 - Code pénal, art. 323-3-1 :
 - Le fait, **sans motif légitime, notamment de recherche ou de sécurité informatique**, d'importer, de détenir, d'offrir, de céder ou de mettre à disposition un équipement, un instrument, un programme informatique ou toute donnée conçus ou spécialement adaptés pour commettre une ou plusieurs des infractions prévues par les articles 323-1 à 323-3 est puni des peines prévues respectivement pour l'infraction elle-même ou pour l'infraction la plus sévèrement réprimée.
 - Code pénal, art. 226-4-1 :
 - Le fait d'usurper l'identité d'un tiers ou de faire usage d'une ou plusieurs données de toute nature permettant de l'identifier en vue de troubler sa tranquillité ou celle d'autrui, ou de porter atteinte à son honneur ou à sa considération, est puni d'un an d'emprisonnement et de 15 000 € d'amende.
 - Cette infraction est punie des mêmes peines lorsqu'elle est commise sur un réseau de communication au public en ligne.
 - Lorsqu'ils sont commis par le conjoint ou le concubin de la victime ou par le partenaire lié à la victime par un pacte civil de solidarité, ces faits sont punis de deux ans d'emprisonnement et de 30 000 euros d'amende.



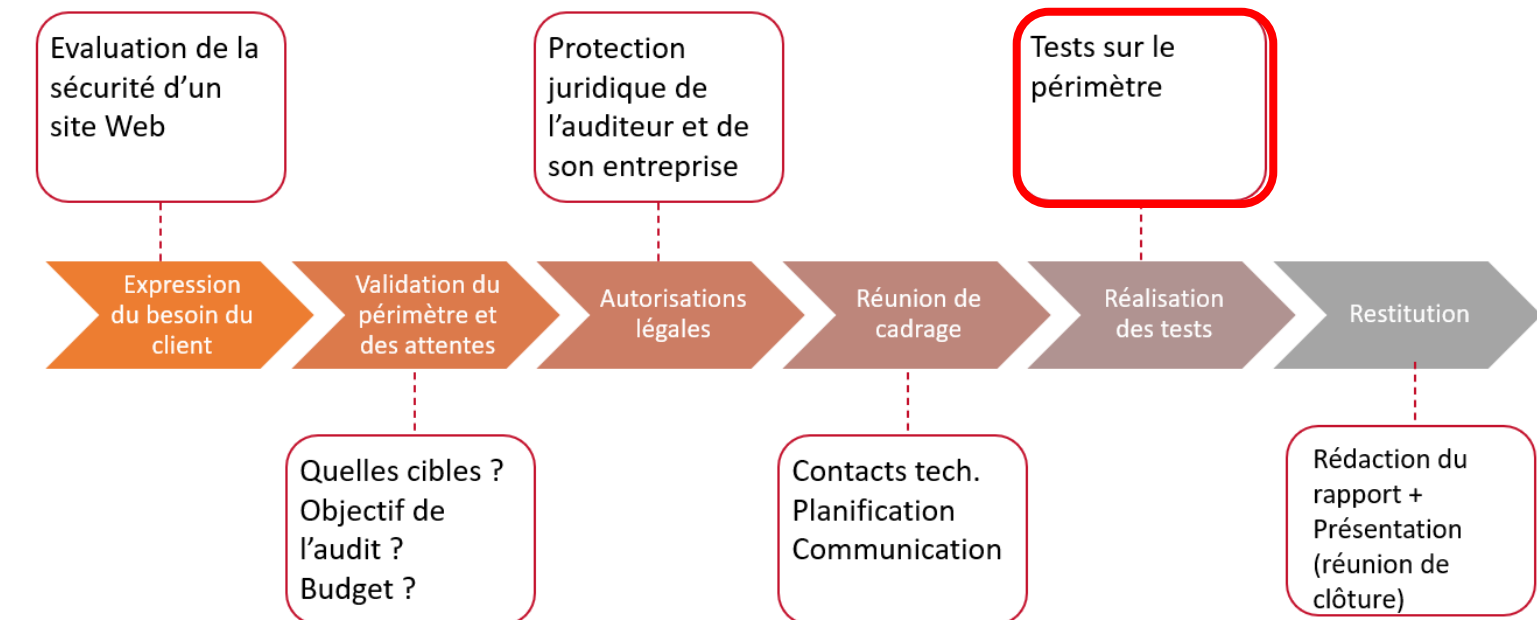
Réunion de cadrage



Répondre aux questions :

- Qui contacter en cas de problème ?
- Qui contacter en cas de découverte de vulnérabilité critique ?
- Comment s'échanger des documents (de façon sécurisée) ?
- Quelles sont les contraintes du client ?
- Planning :
 - Combien de jours pour les tests ?
 - Si plusieurs auditeurs, quelle répartition ?
 - Combien de jours pour rédiger le rapport ?
 - Etablir le planning détaillé

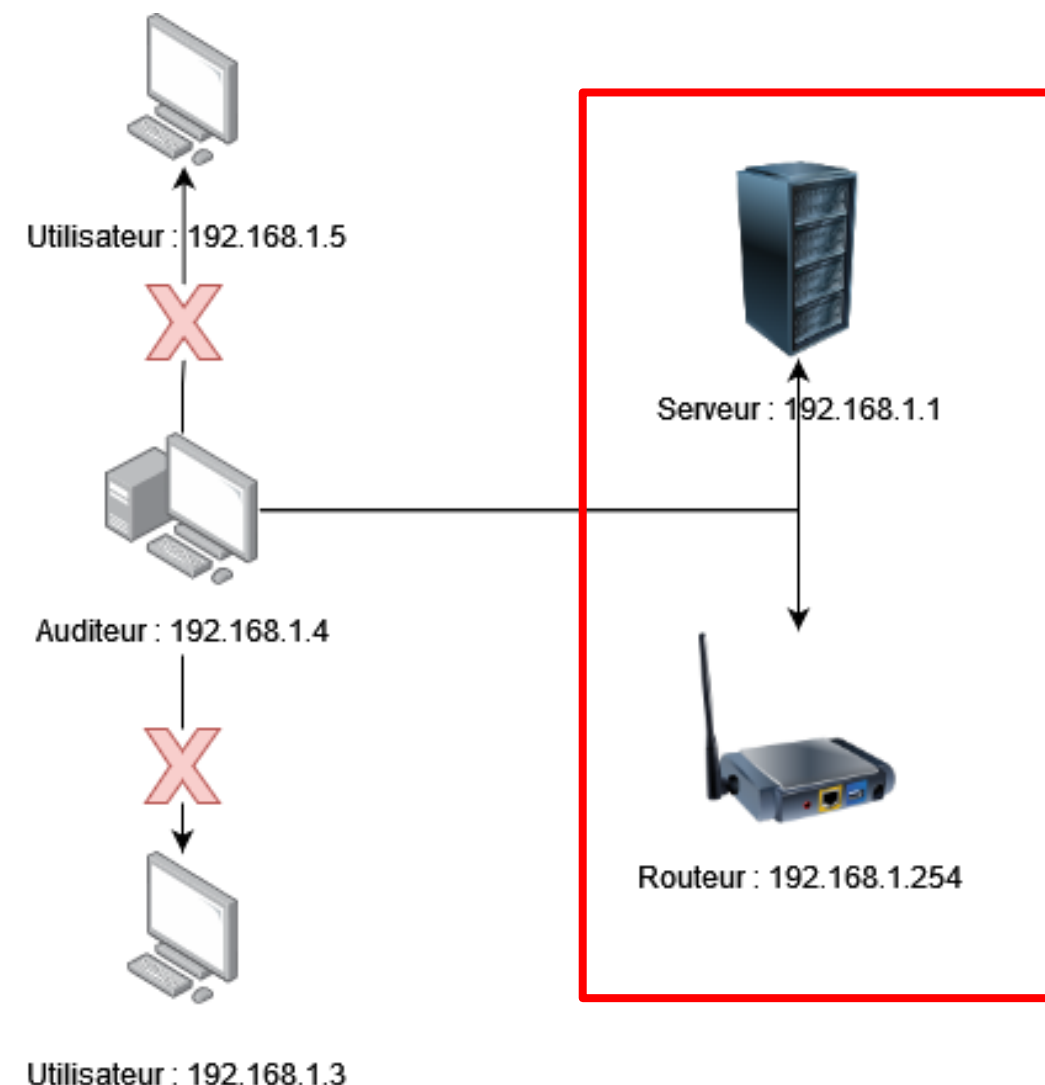
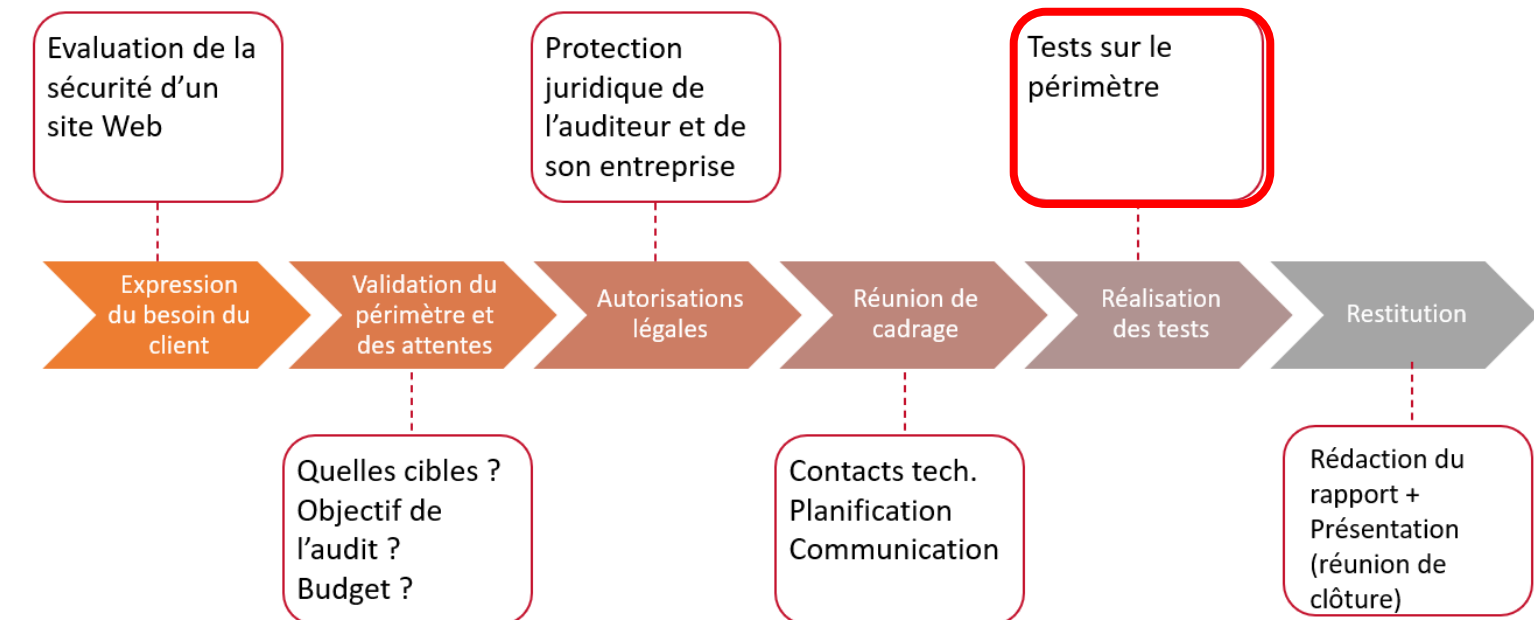
37 Début des tests



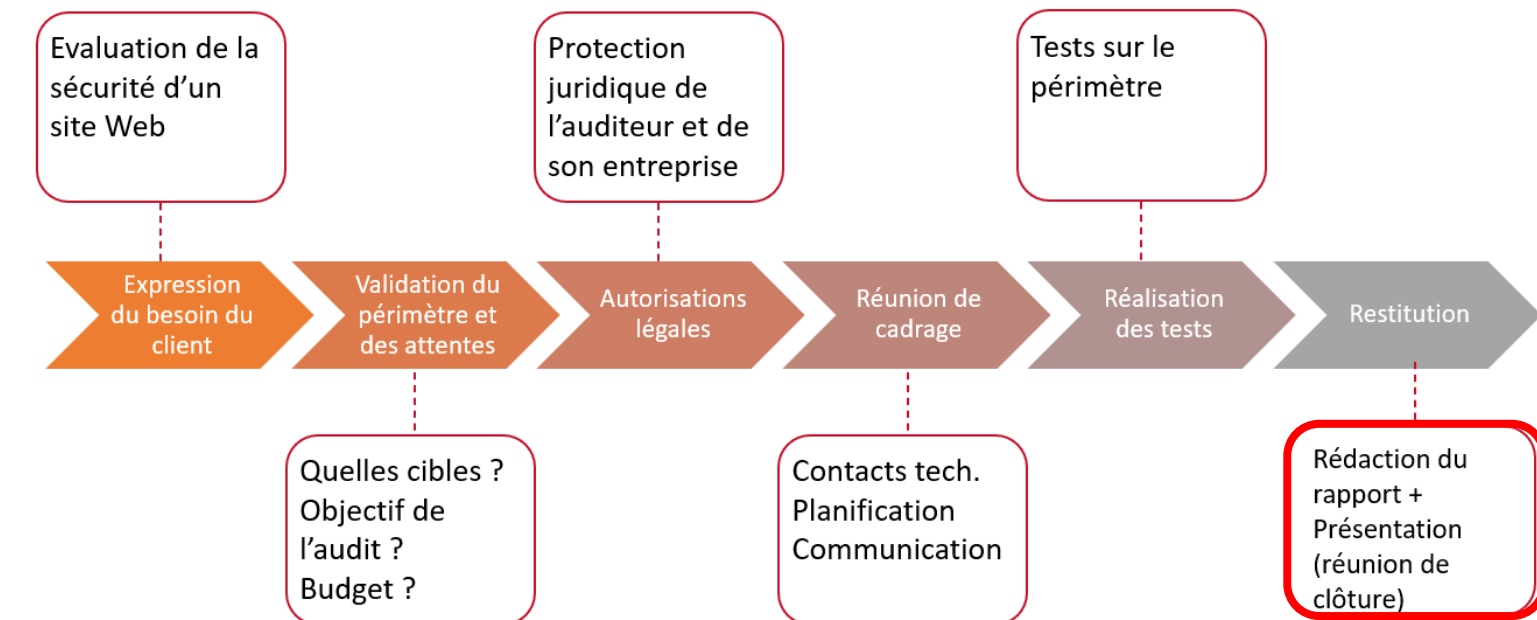
- Respect des contraintes imposées (scénario, horaires, périmètre)
- Être vigilant sur les requêtes envoyées :
 - Risques pour le serveur Web ? DoS ? Modification BDD ?
 - Blocage par un WAF ?

38 Début des tests (exemple)

- Périmètre : 192.168.1.1 et 192.168.1.254
- Ne pas créer de déni-de-service car machines en production
- Utilisateur authentifié : aucun
- Durée : du 06/06/23 au 08/06/23
- Horaires d'audit : 9h00 à 17h00

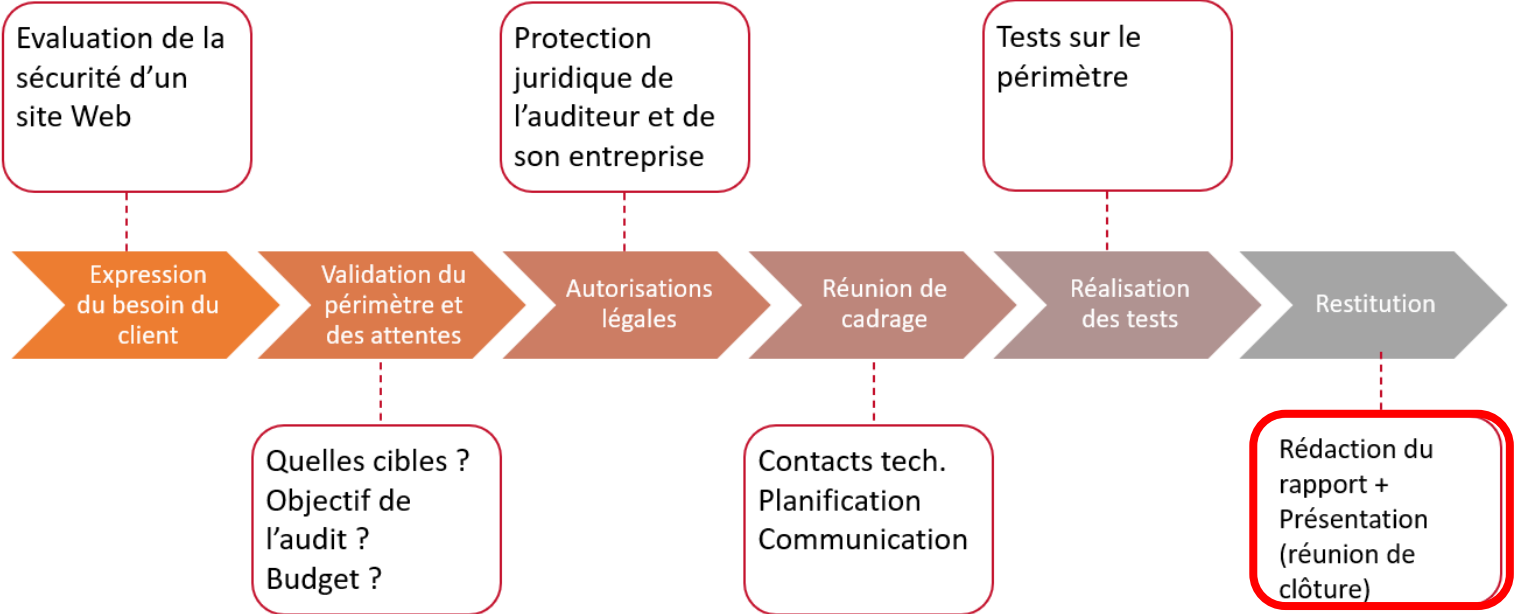


39 Introduction aux tests d'intrusion



- Durée de rédaction : entre 1 jour et 3 jours en moyenne en fonction de la durée de l'audit.
- Contenu :
 - détails du contexte, commanditaire, auditeurs, environnement, dates, tests effectués
 - Liste de toutes les vulnérabilités détectées (avec les preuves) et les recommandations associées
- **Confidentialité** du rapport et de tout ce qui a été trouvé !
- **Destruction** des preuves après livraison

40 Introduction aux tests d'intrusion



Vulnérabilité	
Référence	WEB-BN-V01
Titre	Exécution de code arbitraire sans authentification (CVE-2017-5638)
CWE	CWE-20 (Improper Input Validation)
Machines	
Facilité d'exploitation	Modérée
Niveau d'impact	Critique
Niveau de risque	CRITIQUE
Utilisateur	Aucun
Constats	Le site utilise une version de Struts qui est vulnérable à CVE-2017-5638 et qui permet d'exécuter du code arbitraire sans authentification et sans connaissance particulière du site.
Recommandation	
Description	• Mettre à jour vers une version supérieure à 2.5.10.1
Charge de réalisation	FAIBLE
Priorité	ELEVEE

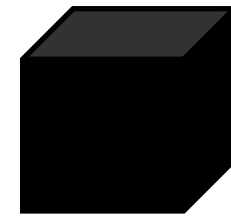
Impact \ Facilité d'exploitation	Facilité d'exploitation			
	Difficile	Elevée	Modérée	Facile
Mineur	Mineur	Mineur	Important	Majeur
Important	Mineur/Important ^o	Important	Important	Majeur
Majeur	Important	Majeur	Majeur	Critique
Critique	Important	Majeur	Critique	Critique

+ captures d'écran pour les preuves

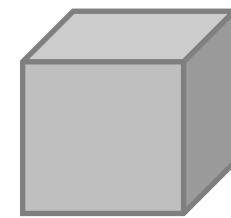
41 Pendant l'audit : les types de tests

➤ En fonction du niveau de connaissance de l'auditeur pour attaquer :

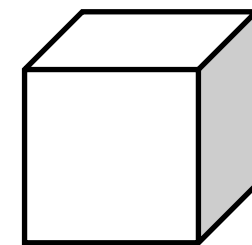
➤ Boite noire



➤ Boite grise



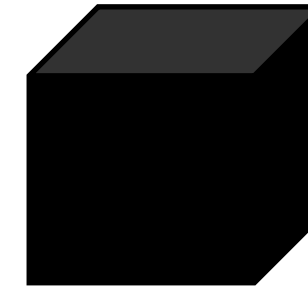
➤ Boite blanche





42

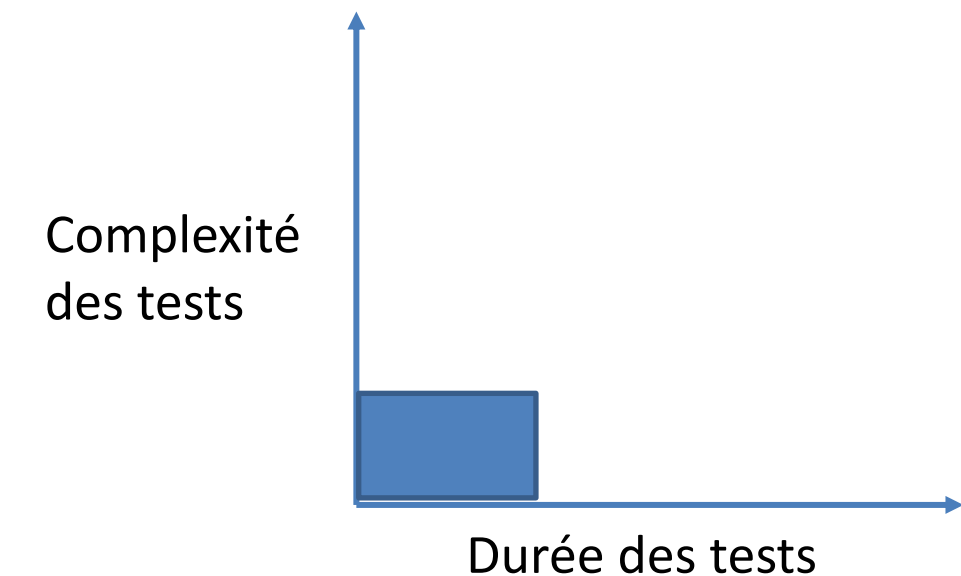
Types de tests : boîte noire



- L'auditeur connaît :
 - Uniquement le périmètre (URL, IP, etc.)
 - Aucune autre information du système

- 😊 Avantages :
 - Condition réaliste pour simuler un attaquant externe
 - Rapide

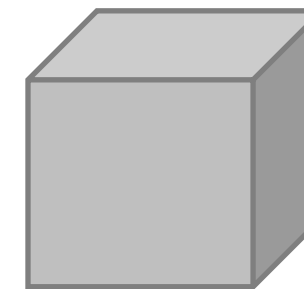
- 😞 Inconvénient : Seules les vulnérabilités les plus évidentes seront détectées



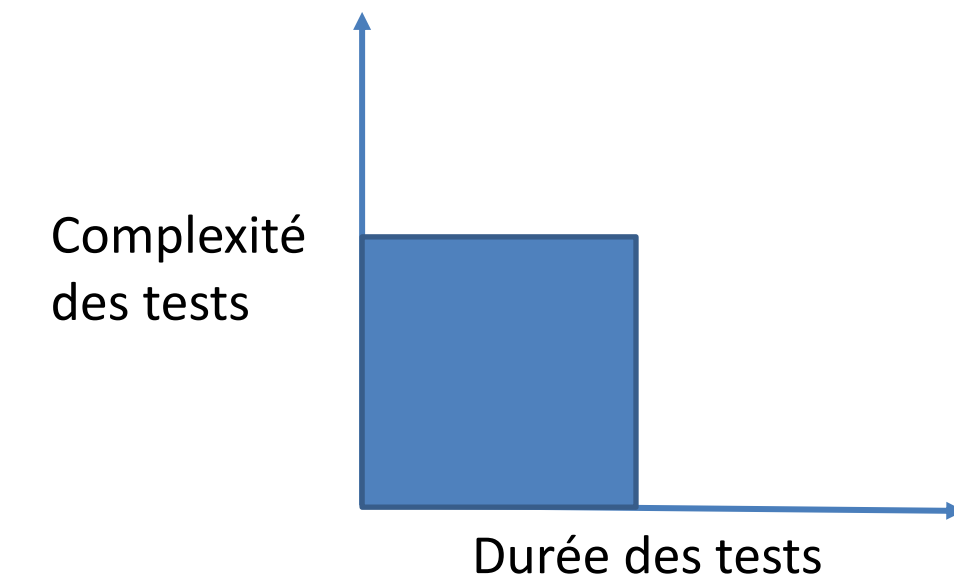


43

Types de tests : boîte grise



- L'auditeur connaît :
 - Le périmètre (URL, IP, etc.)
 - Identifiants/mots de passe d'au moins un utilisateur
 - Aucune autre information du système

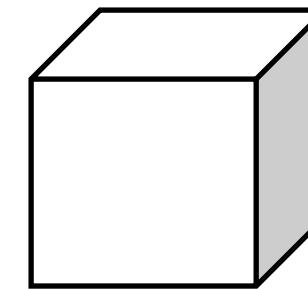


- 😊 Avantages :
 - Condition réaliste pour simuler un attaquant qui serait utilisateur du site Web
 - Des tests supplémentaires sur les autorisations peuvent être réalisés
- 😞 Inconvénient :
 - Certaines vulnérabilités liées à la configuration ou au code source peuvent ne pas être détectées

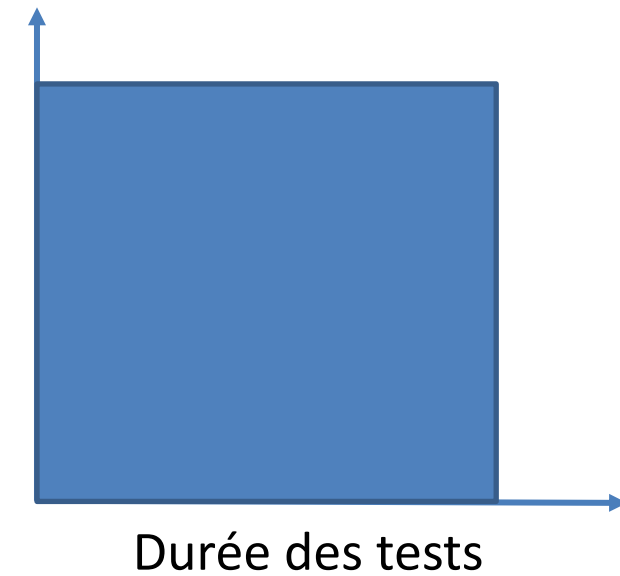


44

Types de tests : boîte blanche



Complexité
des tests



- L'auditeur connaît :
 - Le périmètre (URL, IP, etc.)
 - Identifiants/mots de passe d'au moins un utilisateur
 - Toute autre ressource qui peut être utile (schémas d'architecture, code source, etc.)



Avantages :

- Condition réaliste pour simuler un attaquant interne à l'entreprise
- La couverture des tests est très élevée



Inconvénient :

- La durée des tests sera élevée donc très coûteux



45 Exercice

- Faire le TD 1



46

Méthodologie pendant les tests

- Etape 1 : Rassemblement d'informations (*Information gathering*)
 - Récupération passive d'informations (versions, DNS, infrastructure, Google, Shodan, etc.)
- Etape 2 : Tests applicatifs spécifiques
 - Ex : injection dans des paramètres POST d'un formulaire (XSS ? Injection SQL ?)
- Etape 3 : Exploitation des vulnérabilités
 - S'assurer de l'impact de l'exploitation d'une vulnérabilité (risque de déni-de-service ? Risque de modifier/supprimer un utilisateur ?)



Kali Linux (version 2024.3)



- De nombreux outils présents par défaut :
 - Reconnaissance / récupération d'informations
 - *Social-engineering*
 - Attaques des applications Web
 - Attaques des réseaux sans-fil
 - Attaques sur les réseaux (écoute, usurpation)
 - Attaques de mots de passe
 - *Forensic*
- Cependant, il faudra quand même ajouter des outils :
 - Nuclei, plugins Firefox, BloodHound, etc.

<https://www.kali.org/get-kali/>

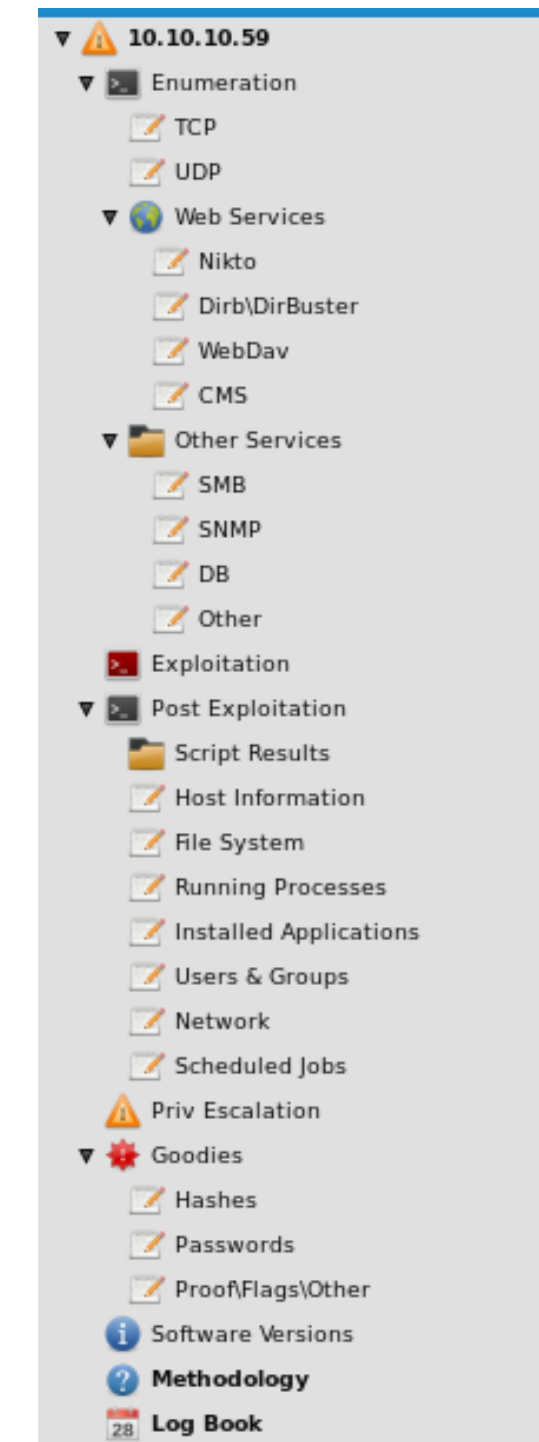


La prise de notes pendant le rapport

- Il faut structurer toutes les informations utiles pour le rapport :
 - CherryTree
 - Obsidian
 - Editeur de texte ?
 - Excel ?
- Cela doit permettre de s'organiser et de retrouver toutes les informations facilement **pour rédiger le rapport.**
- Confidentialité : Ne pas utiliser d'application en ligne ou partagée si contenu sensible.

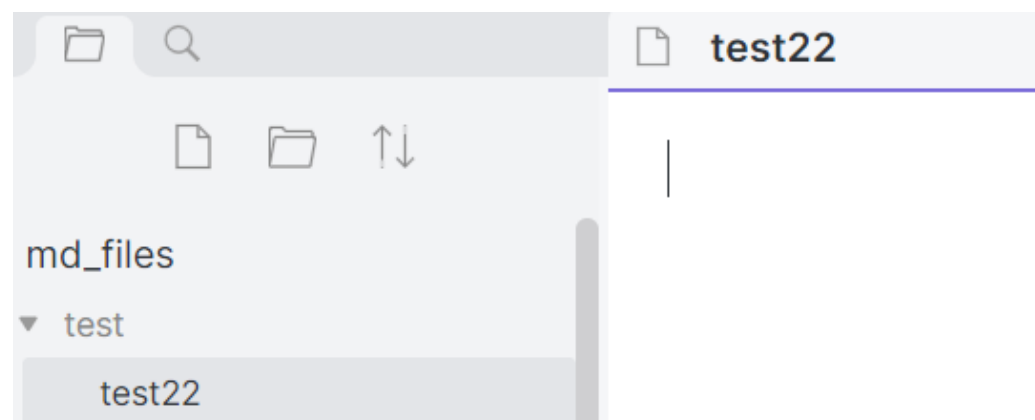
La prise de notes : CherryTree

- Présent de base dans Kali Linux (existe pour Windows)
- Créer une hiérarchie de pages
- Des modèles sont téléchargeables



La prise de notes : Obsidian

- Format Markdown (mode éditeur / visualisation)
- Permet de copier des images / schémas
- Fonctionne sur Linux et Windows



ASLR sous Windows

- Les adresses de la heap et de la stack sont randomisées à chaque exécution du programme (comme sur Linux). Pour ces zones, il nous faudra un nouveau leak à chaque tentative d'exploitation.
- ****Les adresses de base du PE et de ses DLLs sont randomisées à chaque redémarrage de la machine.**** En supposant que le serveur distant ne reboot pas régulièrement (ce qui était le cas pendant le challenge), un même leak sera réutilisable sur plusieurs tentatives d'exploitation même après un crash du programme.

NTDLL.DLL

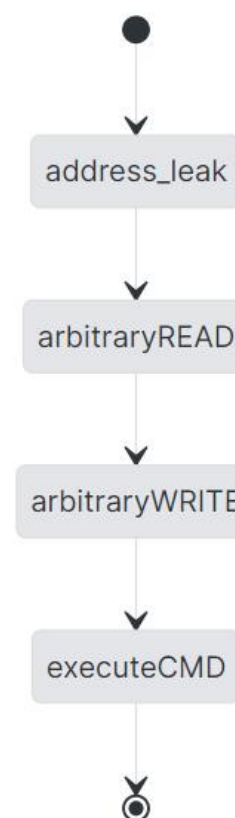
pour les arguments de WinExec

KERNEL32.DLL

pour appeler WinExec

Find ROP gadgets

Principe général



ASLR sous Windows

- Les adresses de la heap et de la stack sont randomisées à chaque exécution du programme (comme sur Linux). Pour ces zones, il nous faudra un nouveau leak à chaque tentative d'exploitation.

51

Pwndoc-ng

- Application web en local
- Génération rapport en docx
- Multi-langages
- Constats
- Recommandations

The screenshot displays the PwnDoc web application interface. The top navigation bar includes 'PwnDoc', 'Audits', 'Vulnerabilities', and 'Datas', along with a user profile 'test'. The left sidebar lists sections: 'General Information', 'Network Scan', 'Findings' (with an 'ADD' button), 'NTLM authentication interception', 'Information Disclosure', 'Directory Traversal', 'Executive Summary', and 'Custom Sections' (with an 'ADD' button). The main content area shows the 'Shared Audit' form with fields for Name, Location, Assessment Type, Company, Client, Collaborators, Redacting Date, Start Date, End Date, Scope, Language, and Template. A 'Save' button is located in the top right corner of the form area.

<https://github.com/pwndoc-ng/pwndoc-ng>

52 La prise de notes

S'organiser et :

- Noter les tests effectués au fur et à mesure (réussites et échecs)
- Noter les comptes utilisés avec les rôles et les actions possibles en fonction des comptes
- Séparer les informations par port détecté
- Noter les technologies découvertes
- Noter les vulnérabilités / faiblesses / points de blocage
- Etc.



Preuves pour le rapport d'audit

- Preuves objectives : données démontrant l'existence ou la véracité de quelque chose. (ISO 19011) Notion de reproductibilité.
- Types de preuves possibles : captures d'écran, procédures, sortie de commandes, rapport d'outils, etc.
- Exemples :
 - Versions vulnérables d'application : capture d'écran
 - Algorithmes faibles sur le certificat : sortie de l'outil sslscan
 - Vulnérabilité :
 - Si CMS : nombre de CVE et CVSS => impact sur l'application
 - Si appli développée : captures d'écran après exploitation



Rapport d'audit

- Donner les indications les plus **précises** possibles :
 - Chemin et fichier vulnérable
 - Nom du paramètre vulnérable avec quelle méthode HTTP
 - Les droits/privilèges/rôles nécessaires pour exploiter la vulnérabilité
 - Les noms des algorithmes
 - Le nom de la machine vulnérable
 - Un exemple de payload

=> Il faut suffisamment d'informations pour reproduire l'exploitation de la vulnérabilité.



55

Rapport d'audit : expliquer une vulnérabilité

- La page `http://192.168.12.30/user.php` contient une **injection SQL** dans le paramètre « `id` » dans une méthode HTTP GET. Un attaquant peut lister tous les utilisateurs de la base de données en utilisant le payload suivant : `1 or 1=1`.
- Diagram labels:
- URL: `http://192.168.12.30/user.php`
 - Nom du paramètre: `id`
 - Type de vulnérabilité: **injection SQL**
 - Méthode HTTP: GET
 - Exemple de payload: `1 or 1=1`
 - Impact: lister tous les utilisateurs de la base de données

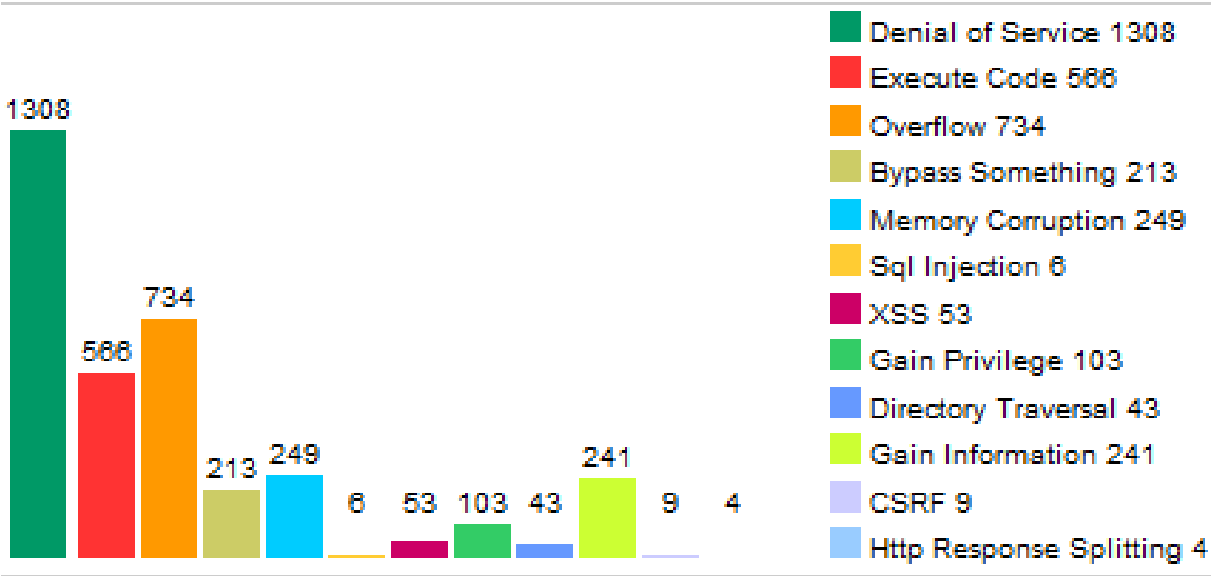
Exploitation : `http://192.168.12.30/user.php?id=1%20or%201=1`

Exemples de descriptions de vulnérabilité

⇒ L'explication est-elle suffisante pour comprendre la vulnérabilité ?

Description	Suffisant ?	Précisions à ajouter
Une injection SQL est présente dans la page /menu.php	✗	IP, paramètre, méthode HTTP, utilisateur
L'algorithme de cryptographie MD5 est utilisé	✗	Chemin fichier, utilisé dans quel but ? impact
Le site utilise HTTP au lieu de HTTPS	✗	Domaine/IP
L'authentification POST de la page https://domaine/login.php peut être contournée via le cookie « logged=1;login=admin »	✓	
La fonction de déconnexion n'est pas implémentée correctement	✗	IP, page
Un IDOR est présent grâce à une XSS et une blind SQL injection.	✗	Incompréhensible !

57 Les CVE

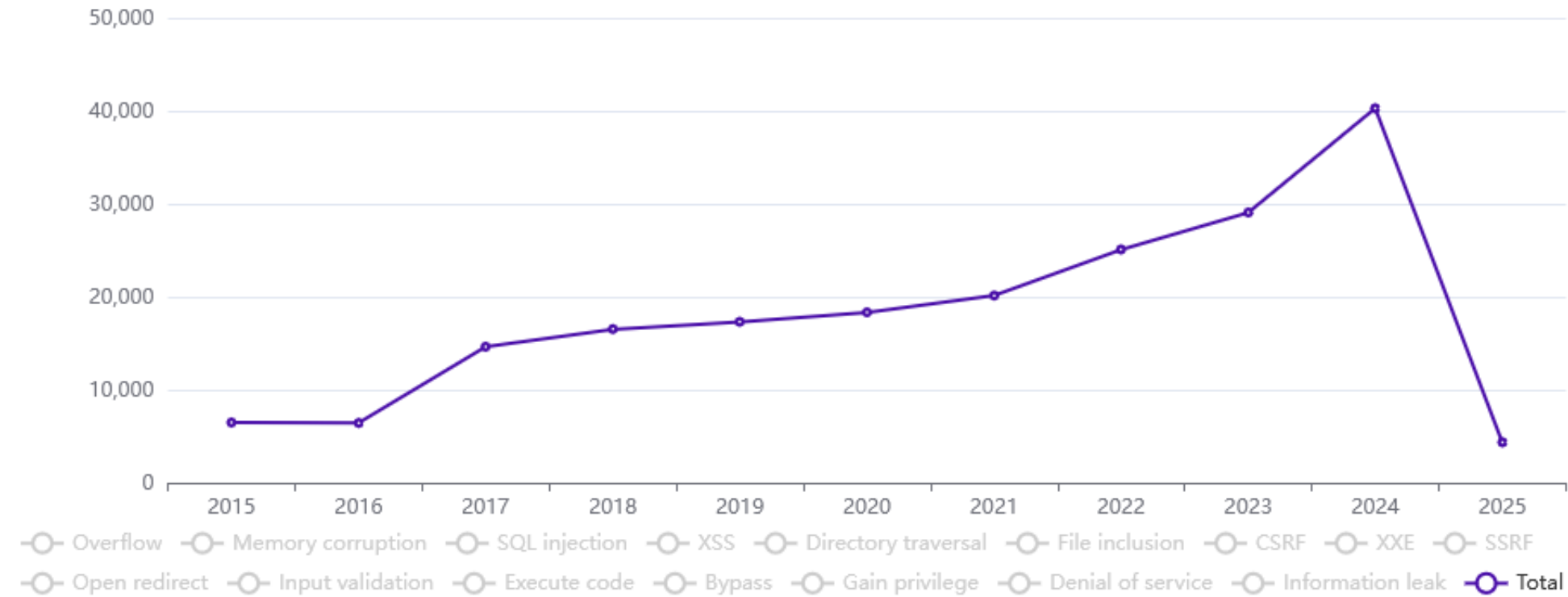


Ubuntu : 3768 CVE depuis 2005

1	Debian Linux	Debian	OS	7636
2	Android	Google	OS	4902
3	Fedora	Fedoraproject	OS	4142
4	Ubuntu Linux	Canonical	OS	3768
5	Mac Os X	Apple	OS	3101
6	Linux Kernel	Linux	OS	3052
7	Windows 10	Microsoft	OS	3029
8	Iphone Os	Apple	OS	2865
9	Windows Server 2016	Microsoft	OS	2837
10	Chrome	Google	Application	2592

Top 10 des produits en nombre de CVE

Vulnerabilities by type & year



Nombre de CVE par année

Source : www.cvedetails.com

Affichage d'une CVE (sur NVD)

CVE-2021-26691 Detail

UNDERGOING REANALYSIS

This vulnerability has been modified and is currently undergoing reanalysis. Please check back soon to view the updated vulnerability summary.

Current Description

In Apache HTTP Server versions 2.4.0 to 2.4.46 a specially crafted SessionHeader sent by an origin server could cause a heap overflow

[+View Analysis Description](#)

Severity

CVSS Version 3.x

CVSS Version 2.0

CVSS 3.x Severity and Metrics:



NIST: NVD

Base Score: **9.8 CRITICAL**

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

NVD Analysts use publicly available information to associate vector strings and CVSS scores. We also display any CVSS information provided within the CVE List from the CNA.

Note: NVD Analysts have published a CVSS score for this CVE based on publicly available information at the time of analysis. The CNA has not provided a score within the CVE List.

QUICK INFO

CVE Dictionary Entry:

CVE-2021-26691

NVD Published Date:

06/10/2021

NVD Last Modified:

02/07/2022

Source:

Apache Software Foundation

Date de
Publication
(format US) :
10 juin 2021

CNA

<https://nvd.nist.gov/details/CVE-2021-26691>

Affichage d'une CVE (sur NVD)

Weakness Enumeration

CWE

CWE-ID	CWE Name	Source
CWE-787	Out-of-bounds Write	NIST
CWE-122	Heap-based Buffer Overflow	Apache Software Foundation

Known Affected Software Configurations [Switch to CPE 2.2](#)

Configuration 1 [\(hide\)](#)

 cpe:2.3:a:apache:http_server:*:*:*:*:*:*	From (including)	Up to (including)
Show Matching CPE(s)	2.4.0	2.4.46

Configuration 2 [\(hide\)](#)

 cpe:2.3:o:debian:debian_linux:9.0:*:*:*:*:*:*	CPE
Show Matching CPE(s)	
 cpe:2.3:o:debian:debian_linux:10.0:*:*:*:*:*:*	CPE
Show Matching CPE(s)	



Les acronymes à connaître

- [CVE](#) (*Common Vulnerabilities Enumeration*) : Identifiant d'une vulnérabilité découverte et rendue **publique**. Ex : CVE-2022-0847
Format : CVE-<année>-<ID>
- [CWE](#) (*Common Weakness Enumeration*) : Identifiant d'une faiblesse. Permet de catégoriser une vulnérabilité. Ex : CWE-502 pour « *Deserialization of Untrusted Data* ».
Format : CWE-<ID>
- [CNA](#) (*CVE Numbering Authority*) : Autorité qui attribue des CVE.
- [CVSS](#) (*Common Vulnerability Scoring System*) : score sur 10 pour évaluer l'impact de la vulnérabilité. V2 différent de V3.
- [CPE](#) (*Common Platform Enumeration*) : nom de l'application
 - Format : cpe:2.3:<type>:<organisation>:<application>:*:*:*:*:*:*:*

Introduction aux tests d'intrusion

- Aller sur <https://cwe.mitre.org/data/index.html>

699 - Software Development

- **C** API / Function Errors - (1228)
 - **B** Use of Inherently Dangerous Function - (242)
 - **B** Use of Function with Inconsistent Implementations - (474)
 - **B** Undefined Behavior for Input to API - (475)
 - **B** Use of Obsolete Function - (477)
 - **B** Use of Potentially Dangerous Function - (676)
 - **B** Use of Low-Level Functionality - (695)
 - **B** Exposed Dangerous Method or Function - (749)

CWE-749: Exposed Dangerous Method or Function

Weakness ID: 749
Abstraction: Base
Structure: Simple

View customized information:

Conceptual

Operational

Mapping-Friendly

Complete

▼ Description

The software provides an Applications Programming Interface (API) or similar interface for interaction with external actors, but the interface includes a dangerous method or function that is not properly restricted.

▼ Extended Description

This weakness can lead to a wide variety of resultant weaknesses, depending on the behavior of the exposed method. It can apply to any number of technologies and approaches, such as ActiveX controls, Java functions, IOCTLs, and so on. The exposure can occur in a few different ways:

- 1) The function/method was never intended to be exposed to outside actors.
- 2) The function/method was only intended to be accessible to a limited set of actors, such as Internet-based access from a single web site.

CWE : Top 25 Most Dangerous Software Weaknesses 2024

2024 CWE Top 25

Rank	ID	Name	Score	CVEs in KEV	Rank Change vs. 2023
1	CWE-79	Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')	56.92	3	+1
2	CWE-787	Out-of-bounds Write	45.20	18	-1
3	CWE-89	Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection')	35.88	4	0
4	CWE-352	Cross-Site Request Forgery (CSRF)	19.57	0	+5
5	CWE-22	Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')	12.74	4	+3
6	CWE-125	Out-of-bounds Read	11.42	3	+1
7	CWE-78	Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection')	11.30	5	-2
8	CWE-416	Use After Free	10.19	5	-4
9	CWE-862	Missing Authorization	10.11	0	+2
10	CWE-434	Unrestricted Upload of File with Dangerous Type	10.03	0	0
11	CWE-94	Improper Control of Generation of Code ('Code Injection')	7.13	7	+12
12	CWE-20	Improper Input Validation	6.78	1	-6
13	CWE-77	Improper Neutralization of Special Elements used in a Command ('Command Injection')	6.74	4	+3
14	CWE-287	Improper Authentication	5.94	4	-1
15	CWE-269	Improper Privilege Management	5.22	0	+7
16	CWE-502	Deserialization of Untrusted Data	5.07	5	-1
17	CWE-200	Exposure of Sensitive Information to an Unauthorized Actor	5.07	0	+13
18	CWE-863	Incorrect Authorization	4.05	2	+6
19	CWE-918	Server-Side Request Forgery (SSRF)	4.05	2	0
20	CWE-119	Improper Restriction of Operations within the Bounds of a Memory Buffer	3.69	2	-3
21	CWE-476	NULL Pointer Dereference	3.58	0	-9
22	CWE-798	Use of Hard-coded Credentials	3.46	2	-4
23	CWE-190	Integer Overflow or Wraparound	3.37	3	-9
24	CWE-400	Uncontrolled Resource Consumption	3.23	0	+13
25	CWE-306	Missing Authentication for Critical Function	2.73	5	-5

<https://cwe.mitre.org/data/definitions/1387.html>

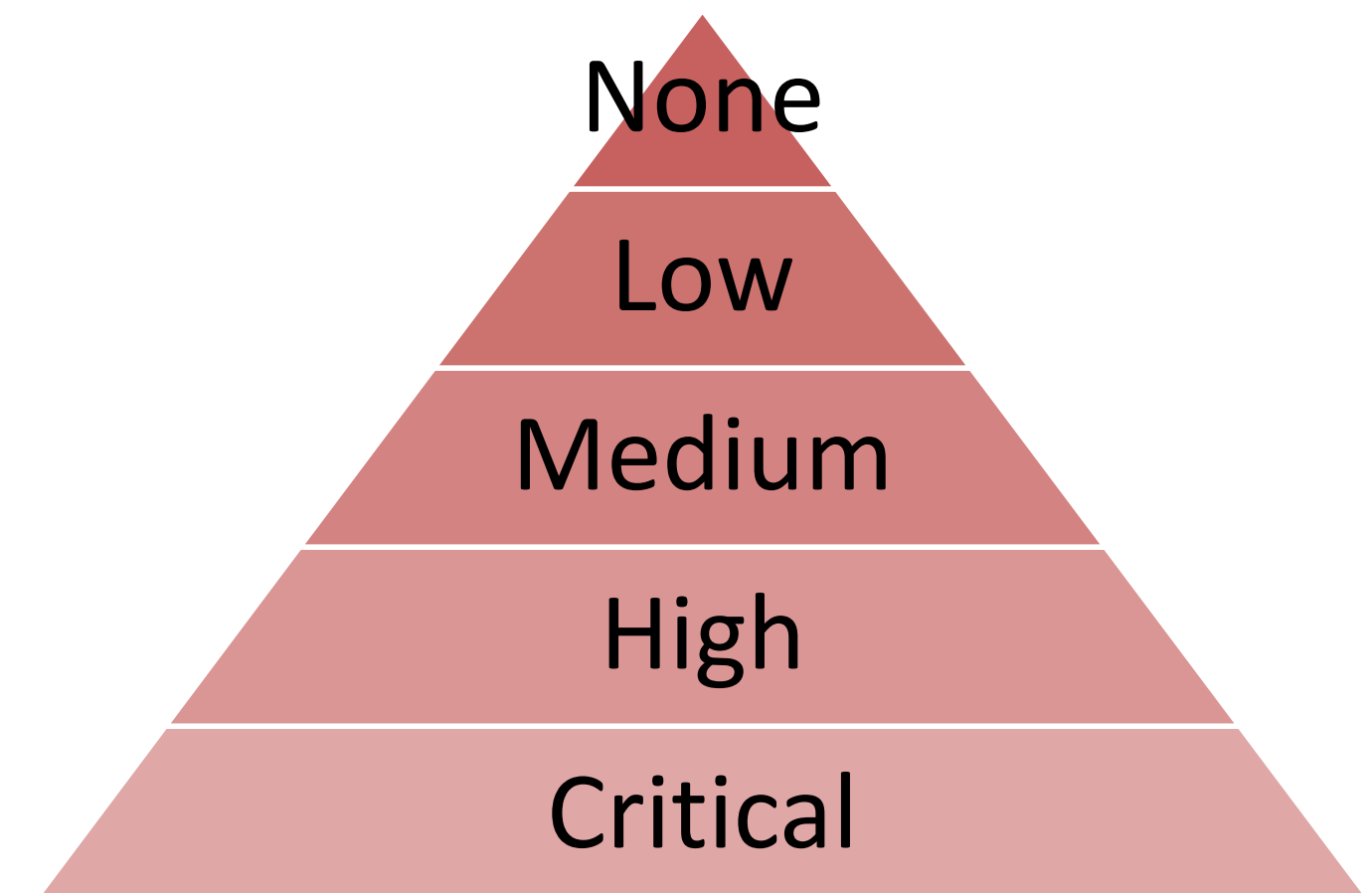


63

CVSS (Common Vulnerability Scoring System)

- Plusieurs versions : v2.0, v3.0 et v3.1, v4
 - Attention : les scores ne sont pas équivalents entre les versions 2 et 3 !
- Score de 1 à 10 (du faible au plus élevé)
 - Calcul entre 3 scores : base, temporal et environment

Severity	Base Score Range
None	0.0
Low	0.1-3.9
Medium	4.0-6.9
High	7.0-8.9
Critical	9.0-10.0



CVSS (Common Vulnerability Scoring System)

Base Score Metrics

Exploitability Metrics

Attack Vector (AV)*

Network (AV:N) Adjacent Network (AV:A) Local (AV:L) Physical (AV:P)

Attack Complexity (AC)*

Low (AC:L) High (AC:H)

Privileges Required (PR)*

None (PR:N) Low (PR:L) High (PR:H)

User Interaction (UI)*

None (UI:N) Required (UI:R)

Scope (S)*

Unchanged (S:U) Changed (S:C)

Impact Metrics

Confidentiality Impact (C)*

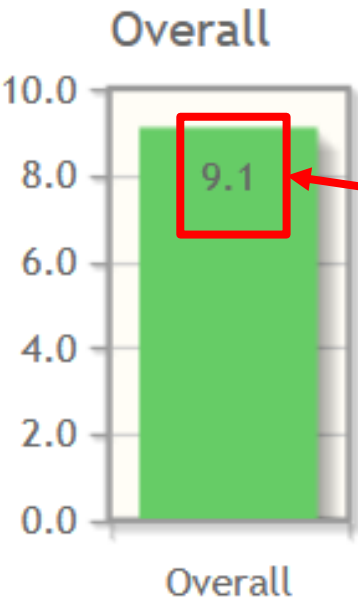
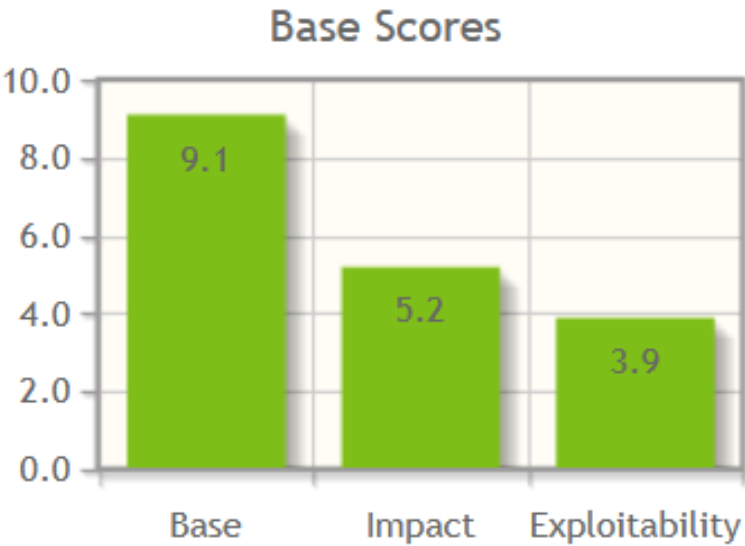
None (C:N) Low (C:L) High (C:H)

Integrity Impact (I)*

None (I:N) Low (I:L) High (I:H)

Availability Impact (A)*

None (A:N) Low (A:L) High (A:H)



CVSS : 9,1

Conclusion

- Intérêt et principe des tests d'intrusion
- Le déroulement, le rapport et les contraintes des tests d'intrusion
- Les CVE

➤ Faire le TD2

